



Cyber Security (CYBER); CRA; Cybersecurity requirements for smart home products with security functionalities

Exercising one of the Principles of international standardization - Openness - and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit: [STAN4CRA / EN 304 632 Smart home security products · GitLab](#) and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

Reference

DEN/CYBER-EUS-0014

Keywords

CRA, cybersecurity, intelligent homes & buildings

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

Reproduction is only permitted for the purpose of standardization work undertaken within ETSI.
The copyright and the foregoing restrictions extend to reproduction in all media.

© ETSI 2026.
All rights reserved.

Contents

1	Intellectual Property Rights	7
2	Foreword.....	7
3	Modal verbs terminology	8
4	1 Scope	9
5	2 References	9
6	2.1 Normative references.....	9
7	2.2 Informative references	9
8	3 Definition of terms, symbols and abbreviations.....	10
9	3.1 Terms	10
10	3.2 Symbols	14
11	3.3 Abbreviations.....	14
12	4 Product context.....	14
13	4.1 Product functions	14
14	4.2 Product Architecture	16
15	4.3 Operational Environment.....	16
16	4.4 Interface.....	17
17	4.5 Distribution of security functions	17
18	4.6 Users	18
19	4.7 Use cases.....	18
20	4.7.1 General	18
21	4.7.2 Use case profiles	18
22	4.8 Security Profiles.....	18
23	5 Requirements specifications.....	19
24	5.1 Product's technical requirements specifications.....	19
25	5.1.1 Known exploitable vulnerabilities.....	19
26	5.1.1.1 [NKEV-MKAV] No known exploitable vulnerabilities.....	19
27	5.1.1.2 [NKEV-SUM-SUPPORT] Secure software update mechanism.....	20
28	5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components	20
29	5.1.1.4 [NKEV-SUM-AUTO] Automated security updates.....	20
30	5.1.1.5 [NKEV-SUM-NOTIF] Update notifications	20
31	5.1.2 Default configuration	20
32	5.1.2.1 [SDC-AUM-FH] Default configuration of authentication for functions whose use can cause harm ...	20
33	5.1.2.2 [SDC-SUM-AUTO] Default configuration of automated security updates.....	20
34	5.1.2.3 [SDC-SUM-NOTIF] Default configuration of update notifications.....	20
35	5.1.2.4 [SDC-FRM] Factory reset to restore the default state	21
36	5.1.3 Authentication and access control mechanisms	21
37	5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm	21
38	5.1.3.2 [AUM-FH] Authentication for functions whose use can cause harm.....	21
39	5.1.3.3 [AUTHZ-LP] Least privilege in authorization policies.....	22
40	5.1.3.4 [AUTHZ-R] Revocability of granted permissions	22
41	5.1.4 Integrity protection.....	22
42	5.1.4.1 [INT-SWPCK] Software package verification	22
43	5.1.4.2 [INT-COM] Communication of integrity relevant data.....	22
44	5.1.5 Confidentiality protection	23
45	5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data	23
46	5.1.5.2 [CONF-COM] Communication of confidential data.....	23
47	5.1.6 Data minimization	24
48	5.1.6.1 [DMIN-DJST] Documented justification of processed data.....	24
49	5.1.7 Availability protection.....	24
50	5.1.7.1 [AVAI-TIME-RECO-POW] Restoration after loss of power	24
51	5.1.7.2 [AVAI-TIME-NETW] Local operation.....	24
52	5.1.7.3 [AVAI-TIME-RECO-NETW] Restoration after loss of network connection	24

55	5.1.7.4	[AVAI-TIME-OUTA-NOT] Notify non-availability	24
56	5.1.7.5	[AVAI-TIME-PREV-NOT] Notify upcoming limitation.....	25
57	5.1.7.6	[AVAI-TIME-NET-PRIO] Network prioritization	25
58	5.1.7.7	[AVAI-TIME-RES-PRIO] Resource prioritization	25
59	5.1.7.8	[AVAI-TIME-IMP-AMP] Amplification control.....	25
60	5.1.7.9	[AVAI-TIME-DOS-RATE] Incoming rate limiting.....	25
61	5.1.7.10	[AVAI-SUM-SCHEDULE] Scheduling of updates	25
62	5.1.8	Impact minimization	25
63	5.1.9	Limit attack surface.....	25
64	5.1.9.1	[LAS-INVAL] Validation of external data input.....	25
65	5.1.9.2	[LAS-INSAN] Sanitization of external data input.....	26
66	5.1.9.3	[LAS-PHY-INF] Only necessary physical interfaces.....	26
67	5.1.9.4	[LAS-LOGIC-INF] Only necessary logical interfaces active by default.....	26
68	5.1.9.5	[LAS-APP] Only necessary apps by default.....	26
69	5.1.9.6	[LAS-SBOOT] Secure boot.....	26
70	5.1.10	Logging and monitoring mechanisms	26
71	5.1.10.1	[LOG-LOW] Events to log for low risk SHPSF.....	26
72	5.1.10.2	[LOG-MEDIUM] Events to log for medium risk SHPSF	26
73	5.1.10.3	[LOG-HIGH] Events to log for high risk SHPSF	27
74	5.1.10.4	[LOG-TIME] Timestamps for logs	27
75	5.1.10.5	[LOG-TIME-HIGH] Real-Timestamps for logs.....	27
76	5.1.10.6	[LOG-STORAGE] Persistently store logfiles	27
77	5.1.10.7	[LOG-BACKUP] Backup of logfiles	27
78	5.1.11	Deletion mechanisms	28
79	5.1.12	Other product's technical requirements specifications	28
80	5.1.12.1	[USERNOT-NOSECFUC] User notifications on not available security functions	28
81	5.2	Requirements specifications for vulnerability handling activities related to the product	28
82	6	Assessing for compliance with requirements.....	28
83	6.1	Assessing for compliance with product's technical requirements specifications	28
84	6.1.1	General.....	28
85	6.1.2	Known exploitable vulnerabilities.....	28
86	6.1.2.1	Assessment criteria for [NKEV-MKAV]	28
87	6.1.3	Default configuration	28
88	6.1.3.1	Assessment criteria for [SDC-FRM]	28
89	6.1.4	Authentication and access control mechanisms	29
90	6.1.4.1	Assessment criteria for [ACM-FH]	29
91	6.1.4.2	Assessment criteria for [AUM-FH].....	30
92	6.1.4.3	Assessment criteria for [AUTHZ-LP]	32
93	6.1.4.4	Assessment criteria for [AUTHZ-R]	32
94	6.1.5	Integrity protection.....	33
95	6.1.6	Confidentiality protection	33
96	6.1.7	Data minimization	33
97	6.1.7.1	Assessment criteria for [DMIN-DJST].....	33
98	6.1.8	Availability protection.....	34
99	6.1.8.1	Assessment criteria for [AVAI-TIME-RECO-POW].....	34
100	6.1.8.2	Assessment criteria for [AVAI-TIME-NETW].....	36
101	6.1.9	Impact minimization	37
102	6.1.10	Limit attack surface.....	37
103	6.1.10.1	Assessment criteria for [LAS-SBOOT].....	37
104	6.1.11	Logging and monitoring mechanisms	38
105	6.1.12	Deletion mechanisms	38
106	6.1.13	Other product's technical requirements specifications	38
107	6.2	Assessment criteria for vulnerability handling activities related to the product	38
108	Annex A (informative):	Relationship between the present document and the requirements of	
109		EU Regulation 2024/2847	39
110	Annex B (informative):	Guidance for the application of the present document	43
111	Annex C (informative):	Information on the methodology for the assessment of cybersecurity	
112		risks used to develop the present document	46

113	C.1	Guidance for determining impact classes.....	46
114	C.1.1	General.....	46
115	C.1.2	confidential data.....	46
116	C.1.3	loss sensitive data	46
117	C.1.4	time sensitive data and time sensitive function.....	47
118	C.1.5	integrity relevant data and integrity relevant function	47
119	Annex D (normative):	Relationship between specific data and functions assets covered by	
120		the present document to impact classes for generic asset categories	49
121	D.1	Identifier.....	49
122	D.2	Data assets	50
123	D.3	Function assets	51
124	D.3.1	functions whose use can cause harm.....	51
125	Annex E (normative):	Protection measures.....	53
126	E.1	Identifier.....	53
127	E.2	access control mechanism's strength	54
128	E.3	authentication mechanism strength	54
129	E.3.1	AUM-FH Authentication for functions whose use can cause harm.....	54
130	E.3.1.1	General	54
131	E.3.1.2	authentication strength level basic	54
132	E.3.1.3	authentication strength level normal	54
133	E.3.1.4	authentication strength level enhanced.....	54
134	E.3.1.5	authentication strength level strong.....	55
135	E.3.2	Assessment for authentication mechanism strength	55
136	E.3.2.1	Assessment criteria regarding the protection against limited presentation attacks.....	55
137	E.3.2.2	Assessment criteria regarding the protection against targeted presentation attacks	56
138	E.3.2.3	Assessment criteria regarding the protection against elaborate presentation attacks	56
139	E.3.2.4	Assessment criteria regarding the protection against limited brute force attacks.....	57
140	E.3.2.5	Assessment criteria regarding the protection against targeted brute force attacks	58
141	E.3.2.6	Assessment criteria regarding the protection against automated brute force attacks	58
142	E.3.2.7	Assessment criteria regarding the protection against presentation attacks.....	59
143	E.3.2.8	Assessment criteria regarding the protection against elaborate brute force attacks	60
144	E.3.2.9	Assessment criteria regarding the protection against automated security token spoofing attacks	60
145	E.3.2.10	Assessment criteria regarding the protection against targeted security token spoofing attacks	61
146	E.3.2.11	Assessment criteria regarding the protection against elaborate security token spoofing attacks	62
147	E.3.2.12	Assessment criteria regarding the protection against replay attacks	62
148	E.3.2.13	Assessment criteria regarding the protection against PitM attacks	63
149	E.4	confidentiality protection strength.....	64
150	E.4.1	CONF-SSM Confidentiality protecting persistent storage for confidential data	64
151	E.4.1.1	General	64
152	E.4.1.2	confidential persistent storage strength level basic	64
153	E.4.1.3	confidential persistent storage strength level normal	64
154	E.4.1.4	confidential persistent storage strength level enhanced	64
155	E.4.1.5	confidential persistent storage strength level strong.....	64
156	E.5	confidentiality protection strength.....	64
157	E.5.1	CONF-COM Communication of confidential data.....	64
158	E.5.1.1	General	64
159	E.5.1.2	communication of confidential data protection strength level basic	64
160	E.5.1.3	communication of confidential data protection strength level normal	65
161	E.5.1.4	communication of confidential data protection strength level enhanced.....	65
162	E.5.1.5	communication of confidential data protect ion strength level strong.....	65
163	E.6	integrity protection strength	65
164	E.6.1	INT-SWPCK Software package verification.....	65
165	E.6.1.1	General	65
166	E.6.1.2	software package integrity verification strength level basic.....	66

167	E.6.1.3	software package integrity verification strength level normal	66
168	E.6.1.4	software package integrity verification strength level enhanced.....	66
169	E.6.2	INT-COM Communication of integrity relevant data	66
170	E.6.2.1	General	66
171	E.6.2.2	communication of integrity relevant data protection strength level basic	66
172	E.6.2.3	communication of integrity relevant data protection strength level normal.....	66
173	E.6.2.4	communication of integrity relevant data protection strength level enhanced	67
174	E.6.2.5	communication of integrity relevant data protection strength level strong	67
175	Annex F (informative):	Relationship between the present document and the covered/not	
176		covered cybersecurity risks.....	68
177	Annex G (informative):	Relationship between the present document and ETSI EN 303 645/	
178		ETSI TS 103 701	71
179	History		72
180			
181			

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

1 Scope

The present document specifies vulnerability handling activities, technical characteristics and corresponding assessment criteria for smart home products with security functionalities related to cybersecurity. Smart home products with security functionalities

- are specified within the "technical description" of the "category of product" number "17." by Regulation (EU) 2025/2392 [i.2] and
- are only covered within the product context described in clause 4.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] under the conditions identified in annex A.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents are necessary for the application of the present document.

- | | |
|-----|---|
| [1] | CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3): "Cybersecurity requirements for products with digital elements - Vulnerability Handling" |
| [2] | Agreed Cryptographic Mechanisms: "European Union Agency for Cybersecurity, European Cybersecurity Certification Group - Sub-group on Cryptography - Agreed Cryptographic Mechanisms." |

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents are not necessary for the application of the present document, but they assist the reader with regard to a particular subject area.

- | | |
|-------|---|
| [i.1] | Regulation (EU) 2024/2847 : "Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)" |
| [i.2] | Regulation (EU) 2025/2392 : "Commission Implementing Regulation (EU) 2025/2392 of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council" |

- 262 [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on
 263 a standardisation request to the European Committee for Standardisation (CEN), the European
 264 Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications
 265 Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU)
 266 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal
 267 cybersecurity requirements for products with digital elements and amending Regulations (EU) No
 268 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)"
- 269 [i.4] CEN/CLC JT013095:2026 (CEN/CLC prEN 40000-1-1): "Cybersecurity requirements for
 270 products with digital elements – Vocabulary"
- 271 [i.5] ETSI EN 304 623 V1.1.1 "Cyber Security (CYBER); CRA; Cybersecurity requirements for boot
 272 managers"

273 3 Definition of terms, symbols and abbreviations

274 3.1 Terms

275 For the purposes of the present document, the terms and definitions given in Regulation (EU) 2024/2847 [i.1],
 276 CEN/CLC JT013095:2026 (CEN/CLC prEN 40000-1-1) [i.4] and the following apply:

277 ARCHITECTURE RELATED TERMS

278 **application software**: software designed to perform specific consumer- or SHPSF-oriented functional tasks on a
 279 device, operating on top of the core software, and without direct responsibility for hardware initialization or
 280 fundamental system control

281 **EXAMPLE:** A mobile app, desktop software or parts of MP's embedded software that implements essential
 282 functionalities.

283 **NOTE:** Application software typically uses APIs provided by core software.

284 **core software**: any software that abstracts hardware, manages hardware resources and provides interfaces for other
 285 software to interact with each other or the core software

286 **EXAMPLE:** A physical MP's operating system, hardware abstraction layer or APIs for application software.

287 **main product**: SHPSF excluding its RDPS

288 COMMUNICATION TYPES

289 **adjacent communication**: public communication limited to a logically adjacent topology or ingoing/outgoing
 290 communication to private networks

291 **local communication**: ingoing/outgoing communication which requires physical access to a communication partner's
 292 interface or proximity of the communication partner to the product

293 **physical communication**: communication that requires physical interchange with the communication partner's
 294 hardware or the hardware the communication partner runs on

295 **public communication**: ingoing/outgoing communication to public networks

296 **strict local communication**: ingoing/outgoing communication which requires physical presence at a communication
 297 partner's interface

298 GENERAL DATA RELATED TERMS

299 **data**: information in digital form

300 **location data**: data containing geographical information

301 **public data**: data from publicly accessible sources

302 **user data**: data provided by a consumer

GENERAL FUNCTIONALITY RELATED TERMS

authorization policy: policy that describes the access rights of entities on SHPSF's data and functions

function output: output of RDPSs' or MP's functions that is:

- a modification or creation of SHPSFs' data or functions
- information intended to inform human users
- information intended to inform or control devices or services; or
- an action on the physical operational environment

function trigger input: input to the RDPSs' or MP's functions provided by:

- human users
- devices or services; or
- the physical operational environment

GENERIC ASSET CATEGORIES

data asset: asset, that is data processed by the SHPSF

confidential data: data asset, whose disclosure can have a negative impact

function, whose use can cause harm: function asset that is:

- a function, whose use can impact the availability of other devices, services or networks;
- a function, whose use can impact the safety or privacy of human entities;
- a function, which can communicate confidential data;
- a function, which can communicate integrity relevant data;
- a function, which can modify integrity relevant data; or
- a function, which can modify integrity relevant functions

function asset: asset, that is a function of the SHPSF

integrity relevant data: data asset, whose tampering can have a negative impact

integrity relevant function: function asset, whose tampering can have a negative impact

loss sensitive data: data asset, whose permanent loss has a negative impact

time sensitive data: data asset, where a time delay in availability has a negative impact

time sensitive function: function asset, where a time delay in availability has a negative impact

GENERAL DATA ASSETS

audio input data: data asset that represents audio information captured by the SHPSF

authorization policy data: data asset that contains an authorization policy

network status data: data asset that describes MPs' or RDPSs' network connections status

EXAMPLE: Assignment of privileges to consumers.

SHPSF state data: data asset that contains SHPSF state information

software package: data asset that contains software intended to be installed on the SHPSF

video input data: data asset that represents video information captured by the SHPSF

EXAMPLE: Video or picture recordings processed (including storage) on the SHPSF.

GENERAL FUNCTION ASSETS

access control mechanism: SHPSF function that enforces an authorization policy

audio input function: SHPSF function that converts audio signals into data

audio output function: SHPSF function that converts data into audio signals

authentication mechanism: SHPSF function that verifies an entity's claim

bootloader function: SHPSF function that initiates the execution of other core software at startup

configuration function: SHPSF function that allows to change the configuration of SHPSF's functions

connection function: SHPSF function that is used for testing or establishing communication capability via machine interface

EXAMPLE: ICMP, DHCP Discovery, function of a SHPSF establishing the connection for remote access or remote alarm transmission.

NOTE: In this context, establishing communication means communication without user data and without authentication of the communication partner for the purpose of establishment of a connection.

factory reset function: SHPSF function that removes all user data and sets the MP in a factory default state, potentially keeping software updates

input sanitization mechanism: SHPSF function that scans function input data and removes or alters parts, that can lead to incidents based on a function specific pattern

input validation mechanism: SHPSF function that rejects input data if it does not meet an accepted pattern

logging mechanism: SHPSF function that logs events

notification mechanism: SHPSF function that notifies entities on certain events

real-time service or clock: service or function that provides real time information

software package verification mechanism: SHPSF function that verifies the integrity and authenticity of software packages

software update mechanism: SHPSF function that allows to change the SHPSF's software

time service or function: service or function that provides time information

video input function: SHPSF function that converts video signals into data

video output function: SHPSF function that converts data into video signals

INTERFACES

human interface: interface that is intended to be used by human

interface: shared boundary across which the SHPSF exchanges information

logical human interface: interface that is a human interface and a logical interface

logical interface: interface that does not exist in hardware and can only be used by using another device or a physical interface of a product with digital elements

machine interface: interface that is intended to be used for machine-to-machine communication

physical interface: interface that is part of the hardware of a SHPSF

physical human interface: interface that is a human interface and a physical interface

OPERATIONAL ENVIRONMENTS

confined operational environment: physical operational environment, where the geographical location is confined to a specific area

fully controlled physical operational environment: physical operational environment, where physical access is fully controlled by the consumer or trusted persons

EXAMPLE: Private house or apartment.

logical operational environment: operational environment describing the accessibility via logical interfaces

mobile operational environment: physical operational environment, where the geographical location is changing during operation and not confined to a specific area

NOTE: Physical operational environment of smartphones and wearables.

partially controlled physical operational environment: physical operational environment, that is not a fully controlled physical operational environment and either under the control of a limited set of persons or located in an area where untrusted physical access is suspicious

EXAMPLE: Shared area in a house with different apartments or private property where public access is not intended.

physical operational environment: operational environment determining the physical accessibility of an architectural component

stationary operational environment: physical operational environment, where the geographical location is fixed

uncontrolled physical operational environment: physical operational environment, where physical access control on arbitrary untrusted entities cannot be ensured for prolonged time periods and where untrusted physical access is not necessarily suspicious

EXAMPLE: Areas intended for public access.

USERS

consumer: natural entity that directly interacts with the SHPSF

VERTICAL SPECIFIC DATA ASSETS

alarm data: data asset intended to alarm entities in hazardous situations

bolt position data: data asset that represents the position of a lock bolt

battery status data: data asset that represents the charge level of a device

lock control data: data asset intended to command the locking or unlocking of a lock

MP position data: location data describing the position of the MP

VERTICAL SPECIFIC DATA RELATED TERMS

void: void.

VERTICAL SPECIFIC FUNCTION ASSETS

positioning function: SHPSF function that determines the MP's position

SHPSF cyber physical alarm function: SHPSF cyber physical function that alarms in hazardous situations

EXAMPLE: Functionality of emitting loud sound or bright lightning signals to attract e.g. neighbourhoods' or household members' attention to a potential fire or an unauthorized physical access to a protected area.

NOTE: As defined a SHPSF cyber physical alarm function does not include a function to communicate alarm data via a logical interface. However, such a function falls under SHPSF function which can communicate alarm data.

SHPSF cyber physical control function: SHPSF function that controls a cyber physical function of a device

SHPSF lock function: SHPSF cyber physical function, that locks or unlocks a lock, without a physical failsafe

SHPSF lock function with failsafe: SHPSF cyber physical function, that locks or unlocks a lock, with a physical failsafe

SHPSF surrounding monitoring function: SHPSF function that monitors noise level or movement

VERTICAL SPECIFIC FUNCTIONALITY RELATED TERMS

cyber physical function: function that performs an action on the physical operational environment

residential physical security function: function which provides function output as reaction to function trigger input related to residential physical security

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

DHCP	Dynamic Host Configuration Protocol
GUI	Graphical User Interface
ICMP	Internet Control Message Protocol
MP	Main Product
PSF	Residential Physical Security Function
RDPS	Remote Data Processing Solution
SHPSF	Smart Home Product With Security Functionalities

4 Product context

4.1 Product functions

The present document addresses the following essential functionalities of SHPSF:

- **PSFs** that might make use of the following functions:
 - audio input function
 - video input function
 - audio output function
 - video output function
 - SHPSF lock function
 - SHPSF cyber physical alarm function
 - SHPSF cyber physical control function
 - SHPSF function which can communicate SHPSF data
 - SHPSF function which can modify SHPSF data

449 The present document addresses the following supporting functionalities of SHPSF:

- 450 • configuration function
- 451 • software update mechanism
- 452 • monitoring mechanism
- 453 • notification mechanism
- 454 • logging mechanism
- 455 • access control mechanism
- 456 • authentication mechanism
- 457 • factory reset function
- 458 • integrity protecting communication mechanism
- 459 • confidentiality protecting communication mechanism
- 460 • integrity protecting secure storage mechanism
- 461 • confidentiality protecting secure storage mechanism
- 462 • deletion mechanism
- 463 • onboarding mechanism
- 464 • input sanitization mechanism
- 465 • input validation mechanism
- 466 • software package verification mechanism
- 467 • bootloader function
- 468 • time service or function
- 469 • real-time service or clock

470 The essential and supporting functionalities might process the following data assets:

- 471 • audio input data
- 472 • video input data
- 473 • network status data
- 474 • authorization policy data
- 475 • SHPSF state data
- 476 • logging data
- 477 • software package
- 478 • MP position data
- 479 • bolt position data
- 480 • battery status data
- 481 • alarm data
- 482 • lock control data

4.2 Product Architecture

The architecture of a SHPSF consists of the following architectural components:

- Software MP or Hardware MP including software
- (optional) App RDPS
- (optional) Cloud RDPS

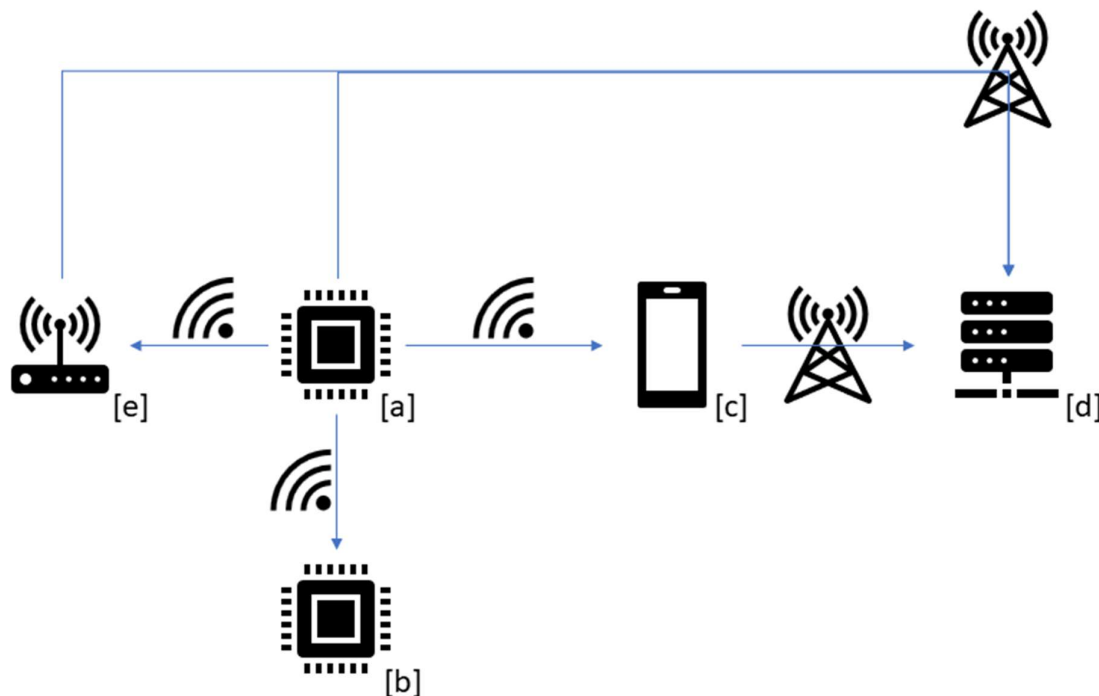


Figure 1: Architectural Components and possible connections between them

Exemplary architectural components and possible connections between them are shown in figure 1. The following components are shown in the figure:

- a) MP
- b) Another SHPSF's MP
- c) App RDPS
- d) Cloud RDPS
- e) A gateway

NOTE: Not all subsets of connected components necessarily correspond to the scope of this standard (see clause 1).

4.3 Operational Environment

The present document addresses the following operational environments of SHPSF.

For the logical operational environment, the following digital communication types are addressed for any architectural component of the SHPSF:

- **public communication** - COM.Public

- 504 • **adjacent communication** - COM.Adjacent
- 505 • **local communication** - COM.Local
- 506 • **strict local communication** - COM.StrictLocal

507 For the physical operational environment, the following environments are addressed for MPs:

- 508 • **fully controlled physical operational environment** - POE.FullyControlled
- 509 • **partially controlled physical operational environment** - POE.PartiallyControlled
- 510 • **mobile operational environment** - POE.Mobile

511 For the physical operational environment, the following environments are addressed for App RDPSs:

- 512 • App RDPS which run on a host device that is intended or reasonably foreseen to be operated in a:
 - 513 - **fully controlled physical operational environment** - POE.FullyControlled
 - 514 - **partially controlled physical operational environment** - POE.PartiallyControlled
 - 515 - **mobile operational environment** - POE.Mobile

516 For the physical operational environment, the following environments are addressed for Cloud RDPSs:

- 517 • Cloud RDPS runs on a host device that is intended or reasonably foreseen to be operated in a
 - 518 - **fully controlled physical operational environment** - POE.FullyControlled

519 4.4 Interface

520 The present document addresses the following interfaces of SHPSF:

- 521 • **human interface** - IF.Human
- 522 • **machine interface** - IF.Machine
- 523 • **logical interface** - IF.Logical
- 524 • **physical interface** - IF.Physical

525 4.5 Distribution of security functions

526 The present document addresses the distribution of security functions among the SHPSF and other products with digital
 527 elements in the SHPSF's context (e.g. host devices for SHPSF's architectural components that are software) by the
 528 following expressions used to formulate the technical requirements specifications in clause [5.1](#).

529 "The SHPSF shall [...] use [some expression related to security functions]" means:

- 530 • the SHPSF itself provides those security functions which are always used, or
- 531 • other products with digital elements in the SHPSF's context provide those security functions which are always
 532 used by the SHPSF.

533 "The SHPSF shall [...] support [some expression related to security functions]" means:

- 534 • the SHPSF itself provides those security functions, or
- 535 • other products with digital elements in the SHPSF's context provide those security functions.

536 "The SHPSF shall [...] provide [some expression related to security functions]" means that the SHPSF itself provides
 537 those security functions.

538 Situations where the SHPSF itself does not provide security functions that are required to be used or supported by the
539 SHPSF and other products with digital elements in the SHPSF's context do not provide those security functions, are
540 addressed in the requirement [USERNOT-NOSECFUC] in clause [5.1.12](#).

541 4.6 Users

542 The present document addresses the following users of SHPSF:

- 543 • Consumers for private usage
- 544 • Manufactures for integration in other products with digital elements intended for consumers

545 4.7 Use cases

546 4.7.1 General

547 The present document addresses all use cases that can be constructed by the previous elements of clause [4](#).

548 4.7.2 Use case profiles

549 In order to classify use cases and to define security profiles the following use case profiles are defined. Those
550 definitions make use of impact classes of functions. The functions covered by the present document are provided in
551 clause [4.1](#), their impact classes in annex [D](#).

552 Use case profile for low impact functions

553 The use case profile for low impact functions bundles all use cases addressed by the present document where the
554 maximum (IMP.FH, IMP.AVAL.TIME) of a SHPSF's function falls under IMP.Low.

555 Use case profile for medium impact functions

556 The use case profile for medium impact functions bundles all use cases addressed by the present document where the
557 maximum (IMP.FH, IMP.AVAL.TIME) of a SHPSF's function falls under IMP.Medium.

558 Use case profile for high impact functions

559 The use case profile for high impact functions bundles all use cases addressed by the present document where the
560 maximum (IMP.FH, IMP.AVAL.TIME) of a SHPSF's function falls under IMP.High.

561 4.8 Security Profiles

562 Based on the use case profiles defined in clause [4.7.2](#) the following security profiles with assigned requirements in
563 table [1](#) are defined:

- 564 • security profile for low impact functions
- 565 • security profile for medium impact functions
- 566 • security profile for high impact functions

567

Table 1: Security profiles with corresponding requirements

Requirement	Security profile for		
	Low impact functions	Medium impact functions	High impact functions
[NKEV-MKAV]	X	X	X
[NKEV-SUM-SUPPORT]	X	X	X
[NKEV-SUM-PROVIDE]	X	X	X
[NKEV-SUM-AUTO]	X	X	X
[NKEV-SUM-NOTIF]	X	X	X
[SDC-AUM-FH]	X	X	X
[SDC-SUM-AUTO]	X	X	X
[SDC-SUM-NOTIF]	X	X	X
[SDC-FRM]	X	X	X
[ACM-FH]	X	X	X
[AUM-FH]	X	X	X
[AUTHZ-LP]	X	X	X
[AUTHZ-R]	X	X	X
[INT-SWPCK]	X	X	X
[INT-COM]	X	X	X
[CONF-SSM]	X	X	X
[CONF-COM]	X	X	X
[AVAI-TIME-RECO-POW]	X	X	X
[AVAI-TIME-NETW]	X	X	X
[AVAI-TIME-RECO-NETW]	X	X	X
[AVAI-TIME-OUTA-NOT]		X	X
[AVAI-TIME-PREV-NOT]			X
[AVAI-TIME-NET-PRIO]		X	X
[AVAI-TIME-RES-PRIO]		X	X
[AVAI-TIME-IMP-AMP]		X	X
[AVAI-TIME-DOS-RATE]			X
[AVAI-SUM-SCHEDULE]		X	X
[LAS-INVAL]	X	X	X
[LAS-INSAN]	X	X	X
[LAS-PHY-INF]	X	X	X
[LAS-LOGIC-INF]	X	X	X
[LAS-APP]	X	X	X
[LAS-SBOOT]			X
[USERNOT-NOSECFUC]	X	X	X
[DMIN-DJST]	X	X	X
[LOG-LOW]	X		
[LOG-MEDIUM]		X	
[LOG-HIGH]			X
[LOG-TIME]	X	X	
[LOG-TIME-HIGH]			X
[LOG-STORAGE]		X	X
[LOG-BACKUP]			X

568

5 Requirements specifications

569

5.1 Product's technical requirements specifications

570

5.1.1 Known exploitable vulnerabilities

571

5.1.1.1 [NKEV-MKAV] No known exploitable vulnerabilities

572

573 In accordance with the vulnerability handling specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1],
 574 the SHPSF shall prior to making available on the market have no insufficiently mitigated known exploitable
 575 vulnerabilities.

NOTE 1: The known exploitable vulnerabilities that occur after making the SHPSF available on the market are subject to the vulnerability handling in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1].

NOTE 2: Typically, products are supplied with all necessary security updates during commissioning.

5.1.1.2 [NKEV-SUM-SUPPORT] Secure software update mechanism

The SHPSF shall support software update mechanisms, that allow to update every part of the SHPSF's software, except for parts of the SHPSF's software, that are immutable due to technical reasons.

EXAMPLE: A mobile RDPS is installed on a device that supports updating the mobile RDPS (e.g. via app-stores)

5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components

All architectural components of the SHPSF that include core software shall provide software update mechanisms, that allow to update every part of the architectural components software, except for parts of the architectural components software, that are immutable due to security.

NOTE: A mobile application typically does not need to provide an update mechanism

5.1.1.4 [NKEV-SUM-AUTO] Automated security updates

The SHPSF shall support the automated update of its software.

5.1.1.5 [NKEV-SUM-NOTIF] Update notifications

The SHPSF shall support the automated notification of its consumers, when updates of its software are available.

5.1.2 Default configuration

5.1.2.1 [SDC-AUM-FH] Default configuration of authentication for functions whose use can cause harm

The SHPSF shall by default be configured to use authentication mechanisms that meet

- the authentication mechanisms strengths specified in clause [E.3.1](#) and
- the minimal authentication mechanisms' strength determined by table [3](#),

except for connection functions.

NOTE: The support of authentication for functions whose use can cause harm is addressed in [AUM-FH].

5.1.2.2 [SDC-SUM-AUTO] Default configuration of automated security updates

The SHPSF shall by default be configured to use automated software update mechanisms for its software.

NOTE: The support of automated security updates is addressed in [NKEV-SUM-AUTO].

5.1.2.3 [SDC-SUM-NOTIF] Default configuration of update notifications

The SHPSF shall by default be configured to use automated notification of its consumers, when updates of the SHPSF's software are available.

NOTE: The support of update notification is addressed in [NKEV-SUM-NOTIF].

5.1.2.4 [SDC-FRM] Factory reset to restore the default state

The SHPSF shall provide a factory reset mechanism that allows a consumer to restore the default state, including the deletion of all user data, installed applications, and configurations deviating from the default state.

NOTE 1: It is also possible that the factory reset will delete the installed security updates if these are installed automatically or on request when the device is commissioned again.

NOTE 2: ANNEX II 8. d) of Regulation (EU) 2024/2847 [i.1] contains legal obligations on how consumers of the SHPSF are informed about secure decommissioning of the SHPSF.

5.1.3 Authentication and access control mechanisms

5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm

The SHPSF shall use access control mechanisms to control entities' use of functions whose use can cause harm, where the applicability of this requirement is determined by table 2 except for connection functions.

Table 2: Assignment for access control mechanisms

			Impact class for function, whose use can cause harm		
			IMP.FH.Low	IMP.FH.Medium	IMP.FH.High
Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input	COM.StrictLocal via IF.Any	POE.FullyControlled	N/A	N/A	applicable[*]
		POE.PartiallyControlled	N/A	applicable[*]	applicable[*]
		POE.Mobile	applicable[*]	applicable[*]	applicable[*]
	COM.Local via IF.HumanPhysical	POE.FullyControlled	N/A	applicable	applicable
		POE.PartiallyControlled	applicable	applicable	applicable
		POE.Mobile	applicable	applicable	applicable
	COM.Local via a non-IF.HumanPhysical COM.Adjacent via IF.Any COM.Public via IF.Any	POE.Any	applicable	applicable	applicable
			applicable	applicable	applicable
			applicable	applicable	applicable
			applicable	applicable	applicable

For protection measures that are labelled with [*] it is not required that the SHPSF uses access control mechanisms for its following functions:

- factory reset function

5.1.3.2 [AUM-FH] Authentication for functions whose use can cause harm

The SHPSF shall support authentication mechanisms, to authenticate entities using functions whose use can cause harm before generating function output, where

- the authentication mechanisms strengths' are specified in clause [E.3.1](#) and
- the minimal required authentication strength is determined by table [3](#),

except for connection functions.

Table 3: Assignment for authentication mechanisms strengths

			Impact class for function, whose use can cause harm		
			IMP.FH.Low	IMP.FH.Medium	IMP.FH.High
Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input	COM.StrictLocal via IF.Any	POE.FullyControlled	N/A	N/A	AUTH.Normal[*]
		POE.PartiallyControlled	N/A	AUTH.Basic[*]	AUTH.Normal[*]
		POE.Mobile	AUTH.Basic[*]	AUTH.Normal[*]	AUTH.Enhanced[*]
	COM.Local via IF.HumanPhysical	POE.FullyControlled	N/A	AUTH.Basic	AUTH.Normal
		POE.PartiallyControlled	AUTH.Basic	AUTH.Normal	AUTH.Enhanced
		POE.Mobile	AUTH.Basic	AUTH.Normal	AUTH.Enhanced
	COM.Local via a non-IF.HumanPhysical	POE.Any	AUTH.Normal	AUTH.Normal	AUTH.Enhanced
	COM.Adjacent via IF.Any		AUTH.Normal	AUTH.Normal	AUTH.Enhanced
	COM.Public via IF.Any		AUTH.Normal	AUTH.Enhanced	AUTH.Enhanced

For protection measures that are labelled with [1] it is not required that the SHPSF uses authentication mechanisms for its following functions:

- factory reset function

5.1.3.3 [AUTHZ-LP] Least privilege in authorization policies

The SHPSF shall use an authorization policy that only grants permissions that are necessary for the intended purpose.

EXAMPLE: A SHPSF with just one consumer grants that consumer all permissions.

5.1.3.4 [AUTHZ-R] Revocability of granted permissions

The SHPSF shall support the revocation of any permission granted by an authorized entity.

EXAMPLE: An administrative consumer can revoke permissions granted to another consumer.

5.1.4 Integrity protection

5.1.4.1 [INT-SWPCK] Software package verification

The SHPSF shall use software package verification mechanisms to verify the integrity and authenticity of software packages prior to installation where the software package verification mechanism's strength levels are specified in clause [E.6.1](#) and where the minimal software package verification mechanism's strength is determined by table [4](#).

NOTE: The requirement addresses software packages that are updates and new software to be installed.

Table 4: Assignment of the software package verification mechanism's strength levels for the verification of software packages

		highest IMP.INT of the SHPSF's integrity relevant functions		
		IMP.INT.Low	IMP.INT.Medium	IMP.INT.High
Attack Surface determined by the COM of RDPS or MP over which the software package is received	COM.StrictLocal	INT.SW.VER.Basic	INT.SW.VER.Basic	INT.SW.VER.Basic
	COM.Local, COM.Adjacent or COM.Public	INT.SW.VER.Normal	INT.SW.VER.Normal	INT.SW.VER.Enhanced

5.1.4.2 [INT-COM] Communication of integrity relevant data

The SHPSF shall use integrity protecting communication mechanisms to protect the integrity of communicated integrity relevant data, where the corresponding integrity protection measures strengths are specified in clause [E.6.2](#) and the minimal required integrity protection measures' strength are determined by table [5](#).

Table 5: Assignment of protection mechanisms strength level for the integrity protection of outgoing data and for the integrity verification of incoming data

			Integrity relevant data impact class		
			IMP.INT.Low	IMP.INT.Medium	IMP.INT.High
Attack Surface determined by COM, IF and POE of RDPS or MP that communicates integrity relevant data	COM.StrictLocal via IF.Machine	POE.Any	INT.COM.Basic	INT.COM.Basic	INT.COM.Basic
	COM.Local via IF.Machine or IF.HumanLogical	POE.FullyControlled	INT.COM.Basic	INT.COM.Basic	INT.COM.Normal
		POE.PartiallyControlled	INT.COM.Basic	INT.COM.Normal	INT.COM.Enhanced
		POE.Uncontrolled	INT.COM.Normal	INT.COM.Enhanced	INT.COM.Enhanced
	COM.Adjacent via IF.Any	POE.Any	INT.COM.Enhanced	INT.COM.Enhanced	INT.COM.Enhanced
	COM.Public via IF.Any		INT.COM.Enhanced	INT.COM.Enhanced	INT.COM.Enhanced

5.1.5 Confidentiality protection

5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data

The SHPSF shall use confidentiality protecting secure storage mechanisms for persistently stored confidential data, where the mechanisms' strength are specified in clause [E.4.1](#) and the minimal required mechanisms' strength are determined by table [6](#).

Table 6: Assignment for confidentiality protecting secure storage mechanisms

		Confidentiality impact class for persistently stored confidential data		
		IMP.CONF.Low	IMP.CONF.Medium	IMP.CONF.High
Attack Surface determined by POE of RDPS or MP that persistently stores confidential data	POE.FullyControlled	N/A	N/A	N/A
	POE.PartiallyControlled	N/A	CONF.SSM.Basic[1]	CONF.SSM.Normal
	POE.Mobile	CONF.SSM.Basic[1]	CONF.SSM.Normal	CONF.SSM.Enhanced

For protection measures labelled with [1], it is not required that the SHPSF uses confidentiality protecting persistent storage for confidential data for confidential data:

- which is persistently stored on non-removable storage

5.1.5.2 [CONF-COM] Communication of confidential data

The SHPSF shall use confidentiality protecting communication mechanisms to protect the confidentiality of communicated confidential data, where the corresponding confidentiality protection measures strengths are specified in clause [E.5.1](#) and the minimal required confidentiality protection measures' strength are determined by table [7](#).

**Table 7: Assignment of protection mechanisms strength level
for the confidentiality of communicated data**

			confidential data impact class		
			IMP.CONF.Low	IMP.CONF.Medium	IMP.CONF.High
Attack Surface determined by COM, IF and POE of RDPS or MP that communicates confidential data	COM.Local via IF.Machine or IF.HumanLogical	POE.FullyControlled	N/A	N/A	CONF.COM.Normal
		POE.PartiallyControlled	N/A	CONF.COM.Basic	CONF.COM.Normal
		POE.Uncontrolled	CONF.COM.Basic	CONF.COM.Normal	CONF.COM.Enhanced
	COM.Adjacent via IF.Any	POE.Any	CONF.COM.Enhanced	CONF.COM.Enhanced	CONF.COM.Enhanced
	COM.Public via IF.Any		CONF.COM.Enhanced	CONF.COM.Enhanced	CONF.COM.Enhanced

5.1.6 Data minimization

5.1.6.1 [DMIN-DJST] Documented justification of processed data

The SHPSF shall only process confidential data according to its intended purpose.

5.1.7 Availability protection

5.1.7.1 [AVAI-TIME-RECO-POW] Restoration after loss of power

The MP shall use a mechanism to resume connectivity and functionality in the case of a loss of power as soon as the power supply is restored.

5.1.7.2 [AVAI-TIME-NETW] Local operation

Where network connectivity is not necessary for a time sensitive function to operate, the SHPSF shall ensure the operability of this function in the case of a loss of network access.

5.1.7.3 [AVAI-TIME-RECO-NETW] Restoration after loss of network connection

The SHPSF shall use a mechanism to reconnect cleanly after a loss of network connection.

EXAMPLE: A SHPSF loses connection to the local network as the network is temporarily unavailable. After recognizing the restored network, the SHPSF reconnects after a randomized delay to reconnect cleanly.

NOTE: *Reconnecting cleanly* normally involves resuming connectivity to network in an expected, operational and stable state and in an orderly fashion taking the capability of the infrastructure into consideration.

5.1.7.4 [AVAI-TIME-OUTA-NOT] Notify non-availability

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the SHPSF, the SHPSF shall use a mechanism to warn the consumer before or at least during a IMP.AVAI.TIME.Medium or higher function becomes unavailable due to CPU, memory, power or network limitations.

EXAMPLE 1: A cloud RDPS recognises a non-availability of its MP and sends a notification to the consumer.

EXAMPLE 2: A SHPSF with a network-dependended IMP.AVAI.TIME.High function recognizes a low bandwidth and sends a notification to the consumer.

5.1.7.5 [AVAI-TIME-PREV-NOT] Notify upcoming limitation

Where at least one time sensitive function with IMP.AVAI.TIME.High is provided by the SHPSF, the SHPSF shall use a mechanism to notify the consumer when the SHPSF recognizes upcoming resource limitations.

EXAMPLE: A battery powered SHPSF recognizes low battery and sends a notification to the consumer.

5.1.7.6 [AVAI-TIME-NET-PRIO] Network prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher with the need of network connectivity for operation is provided by the SHPSF, the SHPSF shall use a mechanism to prioritize the execution of these functions in the case of a network resource conflict.

5.1.7.7 [AVAI-TIME-RES-PRIO] Resource prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the SHPSF, the SHPSF shall use a mechanism to prioritize the execution of these functions in the case of a CPU, memory or power resource conflict.

EXAMPLE: The SHPSF uses the following prioritization in case of resource conflict (high to low priority):

- 1) Time sensitive availability relevant functions.
- 2) Authenticated consumer commands.
- 3) Background tasks (e.g. logging, updates).

NOTE: At least the following resources can cause a processing resource conflict: CPU, memory, power

5.1.7.8 [AVAI-TIME-IMP-AMP] Amplification control

Where at least one function, whose use can impact the availability of other devices, services or networks with IMP.FH.DSN.Medium or higher is provided by the SHPSF, the SHPSF shall use mechanisms to prevent effective amplification of requests or network traffic of these functions.

EXAMPLE: An ICMP request has an amplification factor of three. Then the response time is artificially extended by a factor of tree per destination to have no effective gain in bandwidth.

5.1.7.9 [AVAI-TIME-DOS-RATE] Incoming rate limiting

Where at least one time sensitive function with IMP.AVAI.TIME.High AND at least one machine interface are provided by the SHPSF, the SHPSF shall use mechanisms to discard packets from a source if it sends an unusually high number of requests, whose execution could result in a resource conflict.

5.1.7.10 [AVAI-SUM-SCHEDULE] Scheduling of updates

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the SHPSF, the SHPSF shall support the scheduling of the application of updates that can impact the availability of these function with IMP.AVAI.TIME.Medium or higher.

5.1.8 Impact minimization

5.1.9 Limit attack surface

5.1.9.1 [LAS-INVAL] Validation of external data input

The SHPSF shall use input validation mechanisms for all external data input.

EXAMPLE: If an application expects the input to be an email address, any input that does not conform to the format of an e-mail address will be rejected.

NOTE 1: The specific pattern to accept external data input depends amongst others on the manner the external data input is intended to be processed. This means that an acceptance pattern for broad purposes (such as administration via a "Secure Shell") is typically less specific than an acceptance pattern for a specific purpose (such as a measurement value of a specific format to be stored).

NOTE 2: Typically the validation of different parts of the input will happen at different layers. Network layer of the operating system verify only information relevant to the network. An application verifies only input that is relevant to that application.

5.1.9.2 [LAS-INSAN] Sanitization of external data input

The SHPSF shall use input sanitization mechanisms before using external data input as function input, where the validation of external data input cannot prevent potential incidents triggered by the external data input.

EXAMPLE: If external data input is amongst others intended to be stored via a database service, escape characters and other database service specific commands are removed from the external data input, before it is processed by the database service.

5.1.9.3 [LAS-PHY-INF] Only necessary physical interfaces

A hardware MP shall only provide physical interfaces, that are necessary for the SHPSF's intended purpose.

5.1.9.4 [LAS-LOGIC-INF] Only necessary logical interfaces active by default

The SHPSF shall by default only use logical interfaces, that are necessary for its intended purpose.

5.1.9.5 [LAS-APP] Only necessary apps by default

The SHPSF shall by default only use application softwares, that are necessary for its intended purpose.

5.1.9.6 [LAS-SBOOT] Secure boot

Where at least one function, whose use can cause harm with IMP.FH.High is provided by the SHPSF and the SHPSF includes a hardware MP, the hardware MP shall use a bootloader function that only executes core software at startup, whose integrity and authenticity is verified.

NOTE: The requirement corresponds to the verified boot capability in ETSI EN 304 623 vx.x.x [i.5]

5.1.10 Logging and monitoring mechanisms

5.1.10.1 [LOG-LOW] Events to log for low risk SHPSF

Where the SHPSF has a function, whose use can cause harm of impact class low as its highest function impact class, the SHPSF shall support logging mechanisms to create audit events for every:

- change of configuration affecting core software;
- starts, shutdowns or other changes of operational states of core software;
- errors of the core software.

5.1.10.2 [LOG-MEDIUM] Events to log for medium risk SHPSF

Where the SHPSF has a function, whose use can cause harm of impact class medium as its highest function impact class, the SHPSF shall use logging mechanisms to create audit events for every:

- unsuccessful authentication attempt;
- change of configuration affecting core software;
- starts, shutdowns or other changes of operational states of core software;

- 774 • errors of the core software;
- 775 • unsuccessful attempt of an identity to gain additional privileges;
- 776 • unsuccessful attempt of an identity to access a data asset or function asset.

777 5.1.10.3 [LOG-HIGH] Events to log for high risk SHPSF

778 Where the SHPSF has a function, whose use can cause harm of impact class high as its highest function impact class,
779 the SHPSF shall use logging mechanisms to create audit events for every:

- 780 • every authentication attempt;
- 781 • change of configuration affecting core software;
- 782 • starts, shutdowns or other changes of operational states of core software;
- 783 • change of configuration affecting application software whom realize function, whose use can cause harm of
784 impact class high;
- 785 • starts, shutdowns or other changes of operational states of application software whom realize function, whose
786 use can cause harm of impact class high;
- 787 • errors of the core software;
- 788 • errors of the application software whom realize function, whose use can cause harm of impact class high;
- 789 • every attempt of an identity to gain additional privileges;
- 790 • every attempt of an identity to access a data asset or function asset.

791 5.1.10.4 [LOG-TIME] Timestamps for logs

792 Where the SHPSF does not has a function, whose use can cause harm of impact class high, the SHPSF shall use at least
793 a time service or function to include a timestamp in every audit event, created by the SHPSF.

794 5.1.10.5 [LOG-TIME-HIGH] Real-Timestamps for logs

795 Where the SHPSF has a function, whose use can cause harm of impact class high as its highest function impact class,
796 the SHPSF shall use a real-time service or clock to include a real-time timestamp in every audit event, created by the
797 SHPSF.

798 5.1.10.6 [LOG-STORAGE] Persistently store logfiles

799 Where the SHPSF has a function, whose use can cause harm of impact class medium or higher as its highest function
800 impact class, the SHPSF shall use integrity protecting secure storage mechanisms to store every audit event created by
801 the SHPSF persistently.

802 5.1.10.7 [LOG-BACKUP] Backup of logfiles

803 Where the SHPSF has a function, whose use can cause harm of impact class high as its highest function impact class,
804 the SHPSF shall automatically back up its audit events to another device or another part of the SHPSF that is in another
805 physical location.

5.1.11 Deletion mechanisms

5.1.12 Other product's technical requirements specifications

5.1.12.1 [USERNOT-NOSECFUC] User notifications on not available security functions

The SHPSF shall notify a consumer when security functions that are supposed to be used or supported by the SHPSF are not available.

5.2 Requirements specifications for vulnerability handling activities related to the product

The requirements specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1] shall be fulfilled for the SHPSF.

6 Assessing for compliance with requirements

6.1 Assessing for compliance with product's technical requirements specifications

6.1.1 General

In order to assess the compliance with the requirements listed in clause 5.1 of the present document, the assessment procedures described in clause 6.1 are to be followed. When performing assessments, the distribution of security functions (see clause 4.5) are to be considered, including whether the product provides security functions itself, demands them from other products with digital elements within its context, or supplies them to other products with digital elements.

If there are already existing evidences (e.g. provided by manufacturers of components that are integrated in the SHPSF) that:

- are covering the same assessment activities as described in clause 6.1; and
- are valid for the moment of the assessment to be performed under clause 6.1;

those existing evidences can be used for the "assignment of verdict" and as "supporting evidence".

6.1.2 Known exploitable vulnerabilities

6.1.2.1 Assessment criteria for [NKEV-MKAV]

6.1.3 Default configuration

6.1.3.1 Assessment criteria for [SDC-FRM]

Assessment objective:

The assessment functionally determines whether all user data, installed applications, and configurations deviating from the default state are erased after using the factory reset mechanism.

Assessment preparation:

- Documentation on how the factory reset mechanism can be accessed.
- The SHPSF shall be set up and some configuration changes shall be created and persistently stored.
- Where the SHPSF supports the storage of user data, some user data shall be created and persistently stored on the SHPSF.
- Where the SHPSF supports the installation of applications, some common application for the SHPSF shall be installed.

NOTE: User data also encompasses cryptographic keys, e.g. WIFI passwords, certificates.

Assessment activities:

- An authorised entity shall start the factory reset mechanism.
- The erasure of user data, applications and configurations shall be validated:
 - The restoration of the device settings to their default state shall be validated.
- Attempts to access any previous user accounts or data shall be made.

Assignment of verdict:

The verdict PASS shall be assigned when all user data, installed applications, and configurations deviating from the default state are erased

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- Description of the performed test
- All test records of the performed test

6.1.4 Authentication and access control mechanisms**6.1.4.1 Assessment criteria for [ACM-FH]****Assessment objective:**

The assessment covers:

- a conceptual assessment of ACM-FH;
- a functional completeness assessment on the SHPSF capabilities that are addressed by ACM-FH;
- a functional sufficiency assessment of each access control mechanism used by the SHPSF to fulfil ACM-FH

based on the default configuration required by clause [5.1.2](#).

Assessment preparation:

The following documentation for the SHPSF shall be complete:

- a list of SHPSF's functions whose use can cause harm;
- for each function, whose use can cause harm:
 - its impact class impact class for function, whose use can cause harm;
 - the physical operational environment of the architectural component that performs the function;
 - for each of the function's trigger input possibilities:

- 872 ▪ the interface and communication type;
- 873 ▪ a list of corresponding access control mechanisms including their default authorization policy.

874 The following test setups shall be prepared:

- 875 • a test setup for identifying functions, their trigger input possibilities and corresponding access control mechanisms based on a sample SHPSF in default configuration,
- 876
- 877 • for each access control mechanism, a test setup that allows privilege escalation attacks from authenticated entities and unauthorized access attempts of unauthenticated entities.
- 878

879 **Assessment activities:**

- 880 • The SHPSF's conformity to ACM-FH shall be validated based on the documentation.
- 881 • The correctness and completeness of the documentation shall be verified by:
 - 882 - an inspection of the SHPSF for functions and related access control mechanisms that are accessible via physical human interfaces;
 - 883
 - 884 - a scan of the SHPSF for functions and related access control mechanisms that are accessible via logical interfaces.
 - 885
- 886 • For each access control mechanism, its correct implementation shall be verified based on attempts to violate the authorization policy by:
 - 887
 - 888 - privilege escalation of authenticated entities based on the default authorization policy;
 - 889 - unauthorized usage of function, whose use can cause harm by unauthenticated entities based on the default authorization policy.
 - 890

891 **Assignment of verdict:**

892 The verdict PASS shall be assigned if:

- 893 • the documentation indicates the SHPSF's conformity to ACM-FH; and
- 894 • the verification of the correctness and completeness of the documentation was successful; and
- 895 • the verification of the correct implementation of each access control mechanism was successful.

896 The verdict FAIL shall be assigned otherwise.

897 **Supporting Evidence:**

- 898 • records of the validation of the documentation;
- 899 • descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation;
- 900
- 901 • descriptions of the performed tests and records of performed tests to verify the correct implementation of each access control mechanism.
- 902

903 6.1.4.2 Assessment criteria for [AUM-FH]

904 **Assessment objective:**

905 The assessment covers:

- 906 • a conceptual assessment of AUM-FH;
- 907 • a functional completeness assessment on the SHPSF capabilities that are addressed by AUM-FH;
- 908 • a functional sufficiency assessment of each authentication mechanism used by the SHPSF to fulfil AUM-FH;

based on the default configuration required by clause [5.1.2](#).

Assessment preparation:

The following documentation for the SHPSF shall be complete:

- a list of SHPSF's functions whose use can cause harm.
- for each function, whose use can cause harm:
 - its impact class impact class for function, whose use can cause harm;
 - the physical operational environment of the architectural component that performs the function;
 - for each of the function's trigger input possibilities:
 - the interface and communication type;
 - a list of corresponding authentication mechanisms including:
 - the authentication mechanisms' strength;
 - the type of authentication factors.

The following test setups shall be prepared:

- a test setup for identifying functions, their trigger input possibilities and corresponding authentication mechanisms based on a sample SHPSF in default configuration;
- for each authentication mechanism, a test setup defined by the test cases provided in clause [E.3](#) according to the needs determined by its strength and the type of its authentication factors.

Assessment activities:

- The SHPSF's conformity to ACM-FH shall be validated based on the documentation.
- The correctness and completeness of the documentation shall be verified by:
 - an inspection of the SHPSF for functions and related authentication mechanisms that are accessible via physical human interfaces;
 - a scan of the SHPSF for functions and related authentication mechanisms that are accessible via logical interfaces.
- For each authentication mechanism, its correct implementation shall be verified based on the test cases provided in clause [E.3](#) according to the needs determined by its strength and the type of its authentication factors.

Assignment of verdict:

The verdict PASS shall be assigned if:

- the documentation indicates the SHPSF's conformity to ACM-FH; and
- the verification of the correctness and completeness of the documentation was successful; and
- the verification of the correct implementation of each authentication mechanism was successful.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- records of the validation of the documentation;
- descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation;

- descriptions of the performed tests and records of performed tests to verify the correct implementation of each authentication mechanism.

6.1.4.3 Assessment criteria for [AUTHZ-LP]

Assessment objective:

The assessment covers:

- a conceptual assessment of AUTHZ-LP.

based on the default configuration required by clause [5.1.2](#)

Assessment preparation:

The following documentation for the SHPSF shall be complete:

- a description of the authorization policies in default configuration including:
 - a list of granted permissions for entities on function, whose use can cause harm and
 - for each granted permission, a justification that it is necessary for the intended purpose.

Assessment activities:

- The SHPSF's conformity to {requirement_authz:AUTHZ-LP} shall be validated based on the documentation.

Assignment of verdict:

The verdict PASS shall be assigned if:

- the documentation indicates the SHPSF's conformity to AUTHZ-LP.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- records of the validation of the documentation

6.1.4.4 Assessment criteria for [AUTHZ-R]

Assessment objective:

The assessment covers:

- a functional sufficiency assessment to ensure the SHPSF supports revocation of any granted permissions.

Assessment preparation:

The following documentation for the SHPSF shall be complete:

- a list of mechanisms to grant permissions for entities on function, whose use can cause harm.

The following test setups shall be prepared:

- for each mechanism to grant permissions, a test setup for granting and revoking permissions for entities on function, whose use can cause harm.

Assessment activities:

- For each mechanism to grant permissions, the revocability of grantable permissions shall be verified by:
 - granting permissions to an entity;
 - revoking the permissions; and
 - attempting use permissions after revocation.

Assignment of verdict:

The verdict PASS shall be assigned if:

- for each mechanism to grant permissions, access is denied after revocation.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- descriptions of the performed tests and records of performed tests to verify the correct implementation of AUTHZ-R.

6.1.5 Integrity protection**6.1.6 Confidentiality protection****6.1.7 Data minimization****6.1.7.1 Assessment criteria for [DMIN-DJST]****Assessment objective:**

The assessment covers:

- a conceptual assessment of Documented justification of processed data;
- a functional sufficiency assessment of each mechanism and/or configuration used by the SHPSF to fulfil Documented justification of processed data;
- a functional completeness assessment on the SHPSF capabilities that are addressed by Documented justification of processed data.

Assessment preparation:

The following documentation for the SHPSF shall be complete:

- a list of all documented data sources and destinations to which processed data is transmitted or made accessible (if applicable), processed by the SHPSF in its default configuration;
- a list of all data assets processed by the SHPSF whose impact class for confidential SHPSF data is IMP.CONF.Low or higher;
- for each documented confidential data asset, the associated rationale for its necessity explaining why its processing is necessary for the intended purpose of the SHPSF;
- a description of the mechanisms and/or configurations used to ensure data minimization (e.g. code modules for data filtering, configuration settings that limit data intake, architectural diagrams showing data flows, or policies that prevent unnecessary processing).

NOTE: The documentation of sources and destinations may be combined where a data flow is bidirectional or where source and destination are the same entity.

The following shall be prepared:

- a methodology capable of detecting and listing all data sources actually processed by an SHPSF in its default configuration and, where applicable, the destinations (set up communication partners) to which data is transmitted or made accessible (e.g. network traffic analysis, log inspection, dynamic analysis tools, source-code review where available, interface enumeration, etc.);

- test setups to evaluate the data minimization mechanisms and/or configurations, including attempts to trigger or configure the SHPSF to process additional data beyond the documented and justified items (e.g. via configuration changes, input simulations, or interface probing), based on the described mechanisms and/or configurations.

1023 **Assessment activities:**

- the correctness and completeness of the documentation shall be verified by:
 - using the prepared methodology, identify and list all data sources (and destinations, if applicable) that are actually processed by the sample SHPSF in its default configuration;
 - comparing the identified data sources/destinations with the documented list;
 - for every confidential data item that is documented, verifying that a clear and plausible rationale is provided showing that its processing is necessary for the intended purpose and reasonably foreseeable use;
 - verifying that no confidential data item is processed for which no documentation or no sufficient rationale exists;
 - reviewing the described data minimization mechanisms and/or configurations for conceptual sufficiency (e.g. ensure they align with best practices for limiting data to necessities, such as least-privilege data access or runtime checks); and
 - performing functional tests on the mechanisms and/or configurations using the prepared test setups to confirm they prevent or restrict processing of undocumented or unjustified data (e.g. attempt to enable optional data collection features and verify if they are disabled by default or require explicit justification; simulate inputs that could lead to extra data processing and check if they are filtered or ignored).

1040 **Assignment of verdict:**

1041 The verdict PASS shall be assigned if:

- all actually processed data sources/destinations are documented;
- every documented data item has a sufficient rationale demonstrating necessity for the intended purpose and reasonably foreseeable use;
- no undocumented or unjustified confidential data processing is observed;
- the described mechanisms and/or configurations are conceptually sufficient to enforce data minimization; and
- functional tests confirm that the mechanisms and/or configurations only process necessary data.

1048 Otherwise, the verdict FAIL shall be assigned.

1049 **Supporting Evidence:**

- descriptions of the performed tests and documentation of associated test records to verify the correctness and completeness of the documentation;
- descriptions of the performed tests and documentation of associated test records that verify the correct implementation of each data minimization mechanism and/or configuration.

1054 **6.1.8 Availability protection**

1055 **6.1.8.1 Assessment criteria for [AVAI-TIME-RECO-POW]**

1056 **Assessment objective:**

1057 The assessment covers:

- a functional sufficiency assessment of the recovery function interaction with each power supply used by the SHPSFs MP to fulfil AVAI-TIME-RECO-POW

1060 based on the default configuration required by clause [5.1.2](#).

1061 **Assessment preparation:**

1062 The following documentation for the SHPSF shall be complete:

- 1063 • a list of all power supplies used by the SHPSFs MP:
 - 1064 - for each power supply: a description whether a power supply can power the MP alone
- 1065 • a list of all functionalities of the SHPSF that need communication involving the MP:
 - 1066 - for each of these functionalities:
 - 1067 ▪ a list of interfaces of the SHPSF, where the connection status of the necessary communication
 - 1068 channels can be read ; OR
 - 1069 ▪ parameters of the necessary communication channel of the MP in order to externally observe if the
 - 1070 connection is active
 - 1071 - a list of interfaces of the SHPSF, where the operational status of the MP can be read
 - 1072 ▪ description how the operational status can be implied from the interface readings

1073 The following test setups shall be prepared:

- 1074 • the SHPSF is set up in default configuration
- 1075 • a test setup to:
 - 1076 - safely disconnect or disable and reconnect or enable the power supplies of the SHPSFs MP;
 - 1077 - enable access to at least one interfaces of the SHPSF, where the operational status of the SHPSF can be
 - 1078 read
 - 1079 - enable access to at least one interfaces of the SHPSF, where the connection status the necessary
 - 1080 communication channels status of the MP can be read;
 - 1081 - if the connection status for all necessary communication channels of the MP cannot be read from the
 - 1082 SHPSF:
 - 1083 ▪ monitor whether all necessary communication channels of the MP are active

1084 **Assessment activities:**

1085 The following activities shall be performed:

- 1086 • for every possible order in which the MPs power supplies can be disconnected or disabled:
 - 1087 - disconnect or disable the all power supplies of the MP
 - 1088 - wait at least 30 s
 - 1089 - reconnect or enable the power supplies
 - 1090 - monitor the operational status of the SHPSF
 - 1091 - monitor the connection status for all necessary communication channels of the MP
 - 1092 - record the order in which the power supplies are disconnect or disable and reconnect or enable
 - 1093 - record the time relative to the reconnection or enabling of the last power supply, after which the SHPSF
 - 1094 indicates, that it is operational and all necessary communication channels are established; OR
 - 1095 - record the time relative to the reconnection or enabling of the last power supply, after which every
 - 1096 necessary communication channels of the MP was active at least once, and there is no indication that the
 - 1097 SHPSF has not resumed operation

Assignment of verdict:

The verdict PASS shall be assigned if:

- the SHPSF signals resume of operations and establishment of all necessary communication channels within one hour after the reconnection or enabling of the last power supply; OR
- all necessary communication channels of the MP were active at least once, and there is no indication that the SHPSF has not resumed operation within one hour
- The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- descriptions of the performed tests and records of performed tests

6.1.8.2 Assessment criteria for [AVAI-TIME-NETW]**Assessment objective:**

The assessment covers:

- a conceptual assessment of AVAI-TIME-NETW
- a functional completeness assessment on the SHPSF capabilities that are addressed by AVAI-TIME-NETW
- a functional sufficiency assessment of each time sensitive function without the need of network connectivity to operate used by the SHPSF to fulfil AVAI-TIME-NETW

based on the default configuration required by clause [5.1.2](#).

Assessment preparation:

The following documentation for the SHPSF shall be complete:

- a list of all time sensitive function of the SHPSF
 - for each time sensitive function:
 - description of the functionalities realised or supported by this function
 - list of interfaces necessary for the operation of this function
 - for each interface:
 - communication types of the interface
- a list of interfaces of the SHPSF, where the status of the MPs time sensitive function can be read
 - description how the status can be implied from the interface readings

The following test setups shall be prepared:

- the SHPSF is set up in default configuration;
- a test setup to:
 - disconnect or disable the public communication of the SHPSFs MP;
 - disconnect or disable the adjacent communication of the SHPSFs MP;
 - enable access to at least one interfaces of the SHPSF, where the status of the SHPSFs time sensitive function can be read.

1132 **Assessment activities:**

1133 The following activities shall be performed:

- 1134 • verify the correctness and completeness of the documentation;
- 1135 • repeat the following steps for communication types public communication, adjacent communication and both,
1136 depending on the communication type needed by the functions to be tested:
- 1137 - disconnect or disable the corresponding communication type of the SHPSFs MP;
- 1138 - wait at least 30 s;
- 1139 - for each time sensitive function which does not need any interface with the corresponding
1140 communication type for its operation:
- 1141 ▪ check whether the function is in operable status;
- 1142 ▪ record the status of the function and the disconnected or disabled communication type.
- 1143 - reconnect or enable the corresponding communication type.

1144 **Assignment of verdict:**

1145 The verdict PASS shall be assigned if:

- 1146 • no indication, that the documentation is incorrect or incomplete, are found;
- 1147 • all checked time sensitive functions are in operable state.

1148 The verdict FAIL shall be assigned otherwise.

1149 **Supporting Evidence:**

- 1150 • descriptions of the performed tests and records of performed tests.

1151 **6.1.9 Impact minimization**

1152

1153 **6.1.10 Limit attack surface**

1154 **6.1.10.1 Assessment criteria for [LAS-SBOOT]**

1155 **Assessment objective:**

1156 The assessment covers:

- 1157 • a conceptual assessment of LAS-SBOOT;
- 1158 • a functional sufficiency assessment of the bootloader function used by the SHPSF to fulfil LAS-SBOOT.

1159 based on the default configuration required by clause [5.1.2](#).

1160 **Assessment preparation:**

1161 The following documentation for the SHPSF shall be complete:

- 1162 • SBOM of the SHPSF's hardware MP including information on which software's integrity and authenticity is
1163 protected by the bootloader function;
- 1164 • documentation on how the bootloader function verifies the integrity and authenticity of the hardware MP's
1165 software;

1166 The following test setup shall be prepared:

- 1167 • a test setup for installing integrity and authenticity tampered core software, including a software package
1168 including the tampered core software; or
- 1169 • a test setup for tampering the integrity of installed core software.

1170 **Assessment activities:**

- 1171 • The SHPSF's conformity to LAS-SBOOT shall be validated based on the documentation.
- 1172 • The correct implementation of the bootloader function's integrity and authenticity verification of core software
1173 shall be verified based on:
 - 1174 - tampering the integrity and authenticity of installed core software or installing integrity and authenticity
1175 tampered core software; and
 - 1176 - restarting the SHPSF's hardware MP.

1177 NOTE: Typical results are:

- 1178 • the bootloader function refuses to execute the tampered core software (and thus does not execute application
1179 software); and
- 1180 • either halts, resets, or boots into a secure fallback and
- 1181 • an error indication is provided (e.g. via a log, an error code, an LED pattern, etc.).

1182 **Assignment of verdict:**

1183 The verdict PASS shall be assigned if:

- 1184 • the documentation indicates the SHPSF's conformity to LAS-SBOOT; and
- 1185 • the SHPSF's hardware MP does not execute the modified core software.

1186 Otherwise, the verdict FAIL shall be assigned.

1187 **Supporting Evidence:**

- 1188 • records of the validation of the documentation;
- 1189 • descriptions of the performed tests and documentation of associated test records that verify the correct
1190 implementation of the bootloader function's integrity and authenticity verification.

1191 **6.1.11 Logging and monitoring mechanisms**

1192

1193 **6.1.12 Deletion mechanisms**

1194

1195 **6.1.13 Other product's technical requirements specifications**

1196

1197 **6.2 Assessment criteria for vulnerability handling activities**
1198 **related to the product**

1199 The assessment criteria specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1] shall be met for the
1200 SHPSF based on the corresponding specified input and output.

Annex A (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

The present document has been prepared under the Commission's Standardisation request M/606 - C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A.1: Relationship between the present document and the
requirements of Regulation (EU) 2024/2847 [i.1]**

Harmonised Standard ETSI EN 304 632					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
1	The design, development, and production of products with digital elements ensures an appropriate level of cybersecurity based on the risks.	Annex I, Part I, (1)	[ACM-FH] 5.1.3.1 [AUM-FH] 5.1.3.2 [AUTHZ-LP] 5.1.3.3 [AUTHZ-R] 5.1.3.4 [AVAI-TIME-RECO-POW] 5.1.7.1 [AVAI-TIME-NETW] 5.1.7.2 [AVAI-TIME-RECO-NETW] 5.1.7.3 [AVAI-TIME-OUTA-NOT] 5.1.7.4 [AVAI-TIME-PREV-NOT] 5.1.7.5 [AVAI-TIME-NET-PRIO] 5.1.7.6 [AVAI-TIME-RES-PRIO] 5.1.7.7 [AVAI-TIME-IMP-AMP] 5.1.7.8 [AVAI-TIME-DOS-RATE] 5.1.7.9 [AVAI-SUM-SCHEDULE] 5.1.7.10 [CONF-SSM] 5.1.5.1 [CONF-COM] 5.1.5.2 [DMIN-DJST] 5.1.6.1 [INT-SWPCK] 5.1.4.1 [INT-COM] 5.1.4.2 [LAS-INVAL] 5.1.9.1 [LAS-INSAN] 5.1.9.2 [LAS-PHY-INF] 5.1.9.3 [LAS-LOGIC-INF] 5.1.9.4 [LAS-APP] 5.1.9.5 [LAS-SBOOT] 5.1.9.6 [LOG-LOW] 5.1.10.1 [LOG-MEDIUM] 5.1.10.2 [LOG-HIGH] 5.1.10.3 [LOG-TIME] 5.1.10.4 [LOG-TIME-HIGH] 5.1.10.5 [LOG-STORAGE] 5.1.10.6 [LOG-BACKUP] 5.1.10.7 [NKEV-MKAV] 5.1.1.1 [NKEV-SUM-SUPPORT] 5.1.1.2 [NKEV-SUM-PROVIDE] 5.1.1.3 [NKEV-SUM-AUTO] 5.1.1.4 [NKEV-SUM-NOTIF] 5.1.1.5 [SDC-AUM-FH] 5.1.2.1 [SDC-SUM-AUTO] 5.1.2.2 [SDC-SUM-NOTIF] 5.1.2.3 [SDC-FRM] 5.1.2.4	U	

Harmonised Standard ETSI EN 304 632					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
			[USERNOT-NOSECFUC] 5.1.12.1		
2	Products with digital elements are made available on the market without known exploitable vulnerabilities.	Annex I, Part I, (2)(a)	[NKEV-MKAV] 5.1.1.1	U	
3	Products with digital elements are made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state.	Annex I, Part I, (2)(b)	[LAS-LOGIC-INF] 5.1.9.4 [LAS-APP] 5.1.9.5 [SDC-AUM-FH] 5.1.2.1 [SDC-SUM-AUTO] 5.1.2.2 [SDC-SUM-NOTIF] 5.1.2.3 [SDC-FRM] 5.1.2.4	U	
4	Products with digital elements ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them.	Annex I, Part I, (2)(c)	[NKEV-SUM-SUPPORT] 5.1.1.2 [NKEV-SUM-PROVIDE] 5.1.1.3 [NKEV-SUM-AUTO] 5.1.1.4 [NKEV-SUM-NOTIF] 5.1.1.5 [SDC-SUM-AUTO] 5.1.2.2 [SDC-SUM-NOTIF] 5.1.2.3	U	
5	Products with digital elements ensure protection from Unauthorized access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible Unauthorized access.	Annex I, Part I, (2)(d)	[ACM-FH] 5.1.3.1 [AUM-FH] 5.1.3.2 [AUTHZ-LP] 5.1.3.3 [AUTHZ-R] 5.1.3.4 [LOG-MEDIUM] 5.1.10.2 [LOG-HIGH] 5.1.10.3 [SDC-AUM-FH] 5.1.2.1	U	

Harmonised Standard ETSI EN 304 632					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
6	Products with digital elements protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means.	Annex I, Part I, (2)(e)	[CONF-SSM] 5.1.5.1 [CONF-COM] 5.1.5.2	U	
7	Products with digital elements protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorized by the user, and report on corruptions.	Annex I, Part I, (2)(f)	[INT-SWPCK] 5.1.4.1 [INT-COM] 5.1.4.2 [LOG-LOW] 5.1.10.1 [LOG-MEDIUM] 5.1.10.2 [LOG-HIGH] 5.1.10.3	U	
8	Products with digital elements process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimization).	Annex I, Part I, (2)(g)	[DMIN-DJST] 5.1.6.1	U	
9	Products with digital elements protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks.	Annex I, Part I, (2)(h)	[AVAI-TIME-RECO-POW] 5.1.7.1 [AVAI-TIME-NETW] 5.1.7.2 [AVAI-TIME-RECO-NETW] 5.1.7.3 [AVAI-TIME-OUTA-NOT] 5.1.7.4 [AVAI-TIME-PREV-NOT] 5.1.7.5 [AVAI-TIME-NET-PRIO] 5.1.7.6 [AVAI-TIME-RES-PRIO] 5.1.7.7 [AVAI-TIME-DOS-RATE] 5.1.7.9	U	
10	Products with digital elements minimize the negative impact by the products themselves or connected products on the availability of services provided by other products or networks.	Annex I, Part I, (2)(i)	[AVAI-TIME-IMP-AMP] 5.1.7.8	U	
11	Products with digital elements are designed, developed and produced to limit attack surfaces, including external interfaces.	Annex I, Part I, (2)(j)	[LAS-INVAL] 5.1.9.1 [LAS-INSAN] 5.1.9.2 [LAS-PHY-INF] 5.1.9.3 [LAS-LOGIC-INF] 5.1.9.4 [LAS-APP] 5.1.9.5 [LAS-SBOOT] 5.1.9.6	U	

Harmonised Standard ETSI EN 304 632					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
12	Products with digital elements are designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques.	Annex I, Part I, (2)(k)	[AVAI-TIME-RECO-POW] 5.1.7.1 [AVAI-TIME-NET-PRIO] 5.1.7.6 [AVAI-TIME-RES-PRIO] 5.1.7.7	U	
13	Products with digital elements provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user.	Annex I, Part I, (2)(l)	[LOG-LOW] 5.1.10.1 [LOG-MEDIUM] 5.1.10.2 [LOG-HIGH] 5.1.10.3 [LOG-TIME] 5.1.10.4 [LOG-TIME-HIGH] 5.1.10.5 [LOG-STORAGE] 5.1.10.6 [LOG-BACKUP] 5.1.10.7 [NKEV-SUM-NOTIF] 5.1.1.5 [USERNOT-NOSECFUC] 5.1.12.1	U	
14	Products with digital elements provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.	Annex I, Part I, (2)(m)	[SDC-FRM] 5.1.2.4	U	
15	Vulnerability handling requirements	Annex I, Part II	Clause 5.2	U	

Key to columns:

Requirement:

No A unique identifier for one row of the table which may be used to identify a requirement.

Description A textual reference to the requirement.

Essential requirements of Directive

Identification of article(s) defining the requirement in the Directive.

Clause(s) of the present document

Identification of clause(s) defining the requirement in the present document unless another document is referenced explicitly.

Requirement Conditionality:

U/C Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the manufacturer's claimed functionality of the equipment (C).

Condition Explains the conditions when the requirement is or is not applicable for a requirement which is classified "conditional".

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Guidance for the application of the present document

The following approach can be used (e.g. by manufacturers):

- to develop products that are compliant the present document; or
- to analyse the compliance of a product to the present document.

The approach is constructed such that it uses parts of an assessment of cybersecurity risks and can be integrated into the management of cybersecurity risks.

- Step 1 - check if the product is in scope of the present document provided in clause [1](#) by:
 - verifying that the product is a SHPSF as specified within the "technical description" of the "category of product" number "17." by Regulation (EU) 2025/2392 [i.2]; and
 - identifying the product context by:
 - identifying the product's architectural components; and
 - identifying all data processed by the product (data assets); and
 - identifying all functions provided by the product (function assets); and
 - identifying the architectural components' operational environments; and
 - identifying the architectural components' interfaces and communication types; and
 - verifying that the product is covered within the product context described in clause [4](#) by:
 - verifying that the architectural components of the product are covered within the product architecture described in clause [4.2](#); and
 - verifying that the data processed by the product and the functions provided by the product are covered within clause [4.1](#); and
 - verifying that the architectural components' operational environments are covered within clause [4.3](#); and
 - verifying that the architectural components' interfaces and communication types are covered within clause [4.4](#).

NOTE 1: The identification of the items mentioned above can be reused for assessing the compliance of the product with the requirements in clause [5](#).

NOTE 2: If a product is a SHPSF as specified by Regulation (EU) 2025/2392 [i.2] but is not covered within the product context described in clause [4](#), it is assumed that the product is not or not completely covered by the present document. In such cases informing ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR) via the [Committee Support Staff](#) might help to address those products in potential revisions of the present document.

- Step 2 - identify information to determine risk factors by:
 - identifying for each function provided by the product:
 - its impact classes according to clause [D.3](#); and
 - the architectural components that perform the function; and
 - the communication types and the interfaces that can receive corresponding function trigger input; and
 - identifying for each data processed by the product:

- 1273 ▪ its impact classes according to clause [D.2](#)
- 1274 ▪ the architectural components that persistently store the data; and
- 1275 ▪ the architectural components that can communicate the data; and
- 1276 ▪ the communication types and the interfaces over which the data is communicated.
- 1277 NOTE 3: If data processed by the product or functions provided by the product are not covered within clause [4.1](#),
- 1278 clause [C.1](#) can be used to identify impact classes for function and data assets that are outside the scope of
- 1279 the present document.
- 1280 • Step 3 - identify concrete requirements for and specific security measures/mitigations of the product that
- 1281 satisfy those requirements by:
- 1282 - for each requirement in clause [5](#):
- 1283 ▪ identifying the requirements applicability by evaluating the requirement's potential preconditions
- 1284 and exceptions based on the product's properties; and
- 1285 ▪ (for requirements that include assignment tables) identifying the required protection mechanisms'
- 1286 strengths (specified in annex [E](#)) by evaluating the requirement's assignment table based on the
- 1287 product's properties determining the attack surface and impact parameters; and
- 1288 ▪ identifying the specific security measures/mitigations that satisfy the requirement.
- 1289 NOTE 4: An assignment table can yield multiple mechanisms' strengths from different circumstances, which all
- 1290 have to be satisfied.
- 1291 EXAMPLE: Authentication requirements prior to changes of a SHPSFs configuration are different whether the
- 1292 changes can be made via a web GUI, accessible from adjacent or public networks, a GUI,
- 1293 accessible from the SHPSFs touchscreen, or a console, accessible by connecting to a serial port.
- 1294 All of this cases can be simultaneously present on the same SHPSF.
- 1295 • Step 4 - assess the compliance of the product with the requirements in clause [5](#) by:
- 1296 - for each requirement in clause [5](#), performing the corresponding assessment for compliance described in
- 1297 clause [6](#) (the functional sufficiency assessments for different protection measures strengths are specified
- 1298 in annex [E](#)) by:
- 1299 ▪ preparing the assessment for the product; and
- 1300 ▪ performing the assessment activities for the product; and
- 1301 ▪ assigning an assessment verdict for the product; and
- 1302 ▪ generating the supporting evidences for the assessment.
- 1303 Figure [B.1](#) provides a graphical representation of the guidance for the application of the present document.

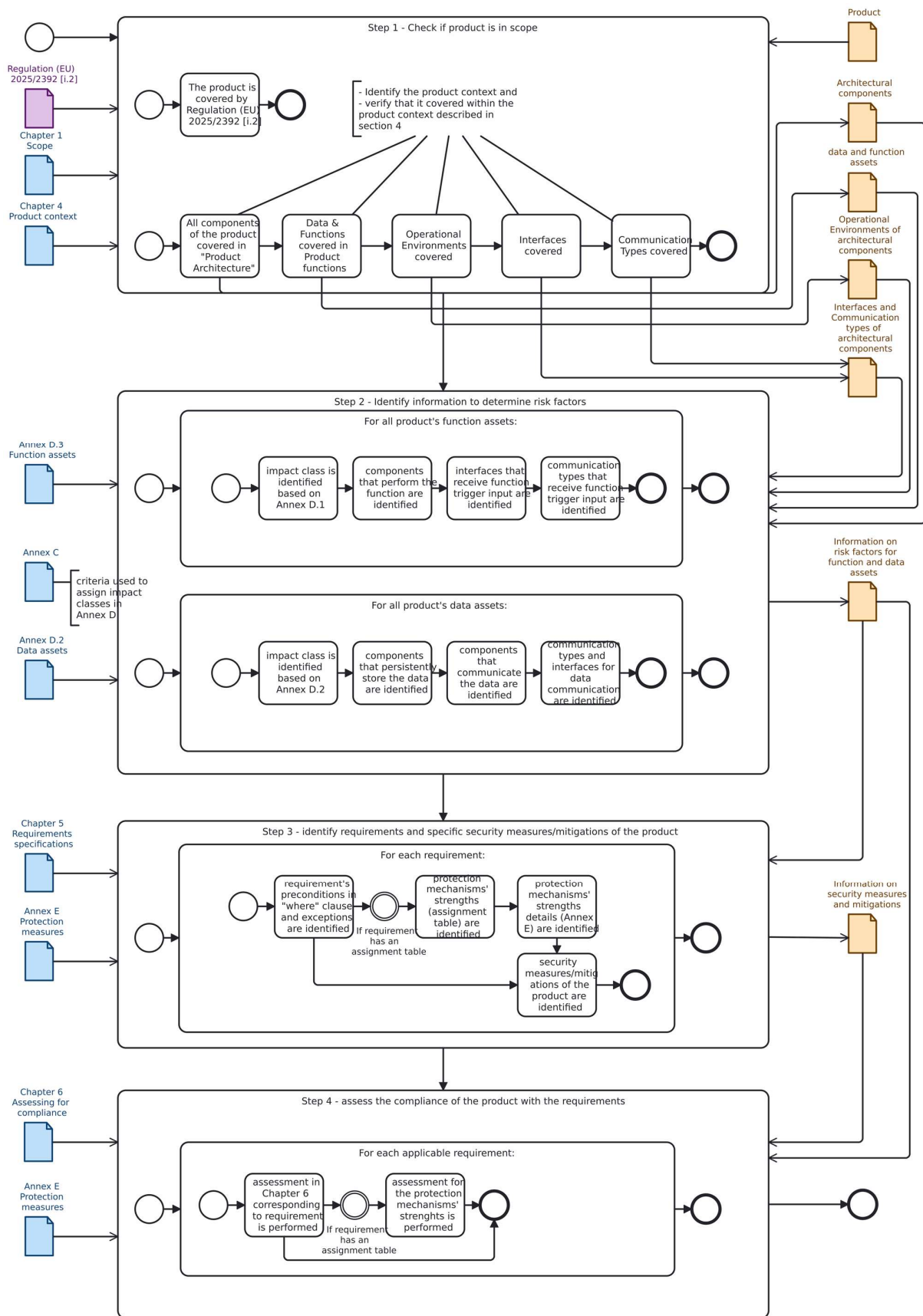


Figure B.1: Graphical representation on guidance for the application of the present document

Annex C (informative): Information on the methodology for the assessment of cybersecurity risks used to develop the present document

This informative annex is intended to provide information on the methodology for the assessment of cybersecurity risks used to develop the present document.

C.1 Guidance for determining impact classes

C.1.1 General

The present document uses the following criteria to determine the impact classes of different specific SHPSF assets provided in annex D.

C.1.2 confidential data

confidentiality impact class low (IMP.CONF.Low):

The disclosure may lead to:

- inconvenient consequences on the consumer(s); or
- additional or increased attack opportunities over a short time and limited to communication types not higher than local on the SHPSF.

confidentiality impact class medium (IMP.CONF.Medium):

The disclosure may lead to:

- serious impact on the consumer(s);
- additional or increased attack opportunities over a short time on the SHPSF or a limited number of other products; or
- additional or increased attack opportunities over a prolonged time limited to non-key-functionalities on the SHPSF.

confidentiality impact class high (IMP.CONF.High):

The disclosure may lead to:

- significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- additional or increased attack opportunities over a prolonged time on the SHPSF or a limited number of other products; or
- additional or increased attack opportunities over a short time on a significant number of other products.

C.1.3 loss sensitive data

loss sensitive availability impact class low (IMP.AVALLOSS.Low):

The loss may lead to:

- inconvenient consequences on the consumer(s); or
- non-availability of non-key-functionalities on the SHPSF for a short time.

1339 **loss sensitive availability impact class medium (IMP.AVALOSS.Medium):**

1340 The loss may lead to:

- 1341 • serious impact on the consumer(s); or
- 1342 • non-availability of key-functionalities of the SHPSF over a short time; or
- 1343 • non-availability of non-key-functionalities on the SHPSF for a prolonged time.

1344 **loss sensitive availability impact class high (IMP.AVALOSS.High):**

1345 The loss may lead to:

- 1346 • significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- 1347 • non-availability of key-functionalities of the SHPSF for a prolonged time; or
- 1348 • permanent non-availability of non-key-functionalities of the SHPSF

1349 **C.1.4 time sensitive data and time sensitive function**

1350 **time sensitive availability impact class low (IMP.AVAL.TIME.Low):**

1351 The delay of availability may lead to:

- 1352 • non-availability of non-key-functionalities on the SHPSF for a short time.

1353 **time sensitive availability impact class medium (IMP.AVAL.TIME.Medium):**

1354 The delay of availability may lead to:

- 1355 • non-availability of key-functionalities on the SHPSF for a short time; or
- 1356 • non-availability of non-key-functionalities on the SHPSF for a prolonged time.

1357 **time sensitive availability impact class high (IMP.AVAL.TIME.High):**

1358 The delay of availability may lead to:

- 1359 • non-availability of key-functionalities of the SHPSF for a prolonged time; or
- 1360 • permanent non-availability of non-key-functionalities of the SHPSF.

1361 **C.1.5 integrity relevant data and integrity relevant function**

1362 **integrity impact class low (IMP.INT.Low):**

1363 The tampering may lead to:

- 1364 • inconvenient consequences on the consumer(s);
- 1365 • additional or increased attack opportunities for a short time and limited to communication types not higher
1366 than local on the SHPSF; or
- 1367 • non-availability of non-key-functionalities on the SHPSF for a short time.

1368 **integrity impact class medium (IMP.INT.Medium):**

1369 The tampering may lead to:

- 1370 • serious impact on the consumer(s);
- 1371 • additional or increased attack opportunities over a short time on the SHPSF or a limited number of other
1372 products;

- 1373 • additional or increased attack opportunities over a prolonged time limited to non-key-functionalities on the
1374 SHPSF; or
- 1375 • non-availability of key-functionalities on the SHPSF for a short time; or
- 1376 • non-availability of non-key-functionalities on the SHPSF for a prolonged time.
- 1377 **integrity impact class high (IMP.INT.High):**
- 1378 The tampering may lead to:
- 1379 • significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- 1380 • additional or increased attack opportunities for a prolonged time on the SHPSF or a limited number of other
1381 products;
- 1382 • additional or increased attack opportunities for a short time on a significant number of other products;
- 1383 • non-availability of key-functionalities of the SHPSF for a prolonged time; or
- 1384 • permanent non-availability of non-key-functionalities of the SHPSF.
- 1385

Annex D (normative): Relationship between specific data and functions assets covered by the present document to impact classes for generic asset categories

D.1 Identifier

The following identifier for impact classes apply:

IMP: impact class

IMP.Low: impact class low

IMP.Medium: impact class medium

IMP.High: impact class high

IMP.CONF: confidentiality impact class

IMP.CONF.Low: confidentiality impact class low

IMP.CONF.Medium: confidentiality impact class medium

IMP.CONF.High: confidentiality impact class high

IMP.INT: integrity impact class

IMP.INT.Low: integrity impact class low

IMP.INT.Medium: integrity impact class medium

IMP.INT.High: integrity impact class high

IMP.AVAL.TIME: time sensitive availability impact class

IMP.AVAL.TIME.Low: time sensitive availability impact class low

IMP.AVAL.TIME.Medium: time sensitive availability impact class medium

IMP.AVAL.TIME.High: time sensitive availability impact class high

IMP.AVAL.LOSS: loss sensitive availability impact class

IMP.AVAL.LOSS.Low: loss sensitive availability impact class low

IMP.AVAL.LOSS.Medium: loss sensitive availability impact class medium

IMP.AVAL.LOSS.High: loss sensitive availability impact class high

IMP.FH: impact class for function, whose use can cause harm

IMP.FH.Low: function, whose use can cause harm impact class low

IMP.FH.Medium: function, whose use can cause harm impact class medium

IMP.FH.High: function, whose use can cause harm impact class high

IMP.FH.SP: function, whose use can impact the safety or privacy of human entities impact class

IMP.FH.SP.Low: function, whose use can impact the safety or privacy of human entities impact class low

IMP.FH.SP.Medium: function, whose use can impact the safety or privacy of human entities impact class medium

- 1419 **IMP.FH.SP.High:** function, whose use can impact the safety or privacy of human entities impact class high
- 1420 **IMP.FH.DSN:** function, whose use can impact the availability of other devices, services or networks impact class
- 1421 **IMP.FH.DSN.Low:** function, whose use can impact the availability of other devices, services or networks impact class
- 1422 low
- 1423 **IMP.FH.DSN.Medium:** function, whose use can impact the availability of other devices, services or networks impact
- 1424 class medium
- 1425 **IMP.FH.DSN.High:** function, whose use can impact the availability of other devices, services or networks impact class
- 1426 high
- 1427 **IMP.FH.CCON:** function, which can communicate confidential data impact class
- 1428 **IMP.FH.CCON.Low:** function, which can communicate confidential data impact class low
- 1429 **IMP.FH.CCON.Medium:** function, which can communicate confidential data impact class medium
- 1430 **IMP.FH.CCON.High:** function, which can communicate confidential data impact class high
- 1431 **IMP.FH.MINT:** function, which can modify integrity relevant data impact class
- 1432 **IMP.FH.MINT.Low:** function, which can modify integrity relevant data impact class low
- 1433 **IMP.FH.MINT.Medium:** function, which can modify integrity relevant data impact class medium
- 1434 **IMP.FH.MINT.High:** function, which can modify integrity relevant data impact class high

D.2 Data assets

Table D.1: Mapping of specific data assets to impact classes for generic data asset categories

specific data asset	impact class for data asset categories			
	impact class for confidential SHPSF data	impact class for integrity relevant SHPSF data	impact class for time critical availability relevant SHPSF data	impact class for loss critical availability relevant SHPSF data
MP position data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Low
bolt position data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium
battery status data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Low	IMP.AVAI.LOSS.Medium
alarm data	IMP.CONF.Low	IMP.INT.High	IMP.AVAI.TIME.High	IMP.AVAI.LOSS.Low
lock control data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium
audio input data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Low	no
video input data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Low	no
network status data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Low
authorization policy data	IMP.CONF.Medium	IMP.INT.High	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Low
SHPSF state data	IMP.CONF.Medium	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Low
logging data	IMP.CONF = IMP.CONF of confidential data contained in the logging data	IMP.INT = Highest /IncludeIDE{ImpactClasses:FunctionWhoseUseCanCauseHarm}	IMP.AVAI.TIME.Low	IMP.AVAI.LOSS.Medium
software package	IMP.CONF = IMP.CONF of confidential data contained in the package	IMP.INT = Highest IMP.INT of SHPSF's integrity relevant function	no	no

D.3 Function assets

Table D.2: Mapping of specific function assets to impact classes for generic function asset categories

specific function asset	impact class for function asset categories		
	impact class for integrity relevant function	impact class for time sensitive function	impact class for function, whose use can cause harm
SHPSF lock function	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.FH.High
SHPSF cyber physical alarm function	IMP.INT.High	IMP.AVAI.TIME.High	IMP.FH.Medium
positioning function	IMP.INT.Medium	IMP.AVAI.TIME.Medium	no
SHPSF cyber physical control function	IMP.INT.High	IMP.AVAI.TIME = IMP.AVAI.TIME of the controlled cyber physical function	IMP.FH = IMP.FH of the controlled cyber physical function
SHPSF surrounding monitoring function	IMP.INT.Medium	IMP.AVAI.TIME.High	IMP.FH.Medium
SHPSF lock function with failsafe	IMP.INT.Medium	IMP.AVAI.TIME.Low	IMP.FH.High
audio input function	IMP.INT.Medium	IMP.AVAI.TIME.Low	IMP.FH.Medium
video input function	IMP.INT.Medium	IMP.AVAI.TIME.Low	IMP.FH.Medium
audio output function	IMP.INT.Medium	IMP.AVAI.TIME.Low	IMP.FH.Medium
video output function	IMP.INT.Medium	IMP.AVAI.TIME.Low	IMP.FH.Medium
SHPSF function which can communicate SHPSF data	IMP.INT = Maximum (IMP.CONF, IMP.INT) of communicated data	IMP.AVAI.TIME = IMP.AVAI.TIME of communicated data	IMP.FH = Maximum (IMP.FH.Low, IMP.CONF of communicated data)
connection function	IMP.INT.Low	IMP.AVAI.TIME.Low	IMP.FH.Medium
SHPSF function which can modify SHPSF data	IMP.INT = IMP.INT of modified data	no	IMP.FH = IMP.INT of modified data

D.3.1 functions whose use can cause harm

The contents of the column *impact class for function, whose use can cause harm* of table [D.2](#) are split into details in table [D.3](#).

Table D.3: Mapping of specific function assets to impact classes for different aspects of function, whose use can cause harm

specific function asset	impact class for function asset categories				
	impact class for function, whose use can impact the safety or privacy of human entities	impact class for function, whose use can impact the availability of other devices, services or networks	impact class for function, which can communicate confidential data	impact class for function, which can modify integrity relevant data	impact class for function, whose use can cause harm
SHPSF lock function	IMP.FH.SP.High	no	no	no	IMP.FH.High
SHPSF cyber physical alarm function	IMP.FH.SP.Medium	no	no	no	IMP.FH.Medium
positioning function	IMP.FH.SP.Medium	no	no	IMP.FH.MINT.Medium	no
SHPSF cyber physical control function	IMP.FH.SP = IMP.FH.SP of the controlled cyber physical function	no	IMP.FH.CCON = IMP.CONF of communicated control data	no	IMP.FH = IMP.FH of the controlled cyber physical function
SHPSF surrounding monitoring function	IMP.FH.SP.High	no	IMP.FH.CCON.High	no	IMP.FH.Medium
SHPSF lock function with failsafe	IMP.FH.SP.High	no	no	no	IMP.FH.High
audio input function	IMP.FH.SP.Medium	no	no	no	IMP.FH.Medium
video input function	IMP.FH.SP.Medium	no	no	no	IMP.FH.Medium
audio output function	IMP.FH.SP.Medium	no	no	no	IMP.FH.Medium
video output function	IMP.FH.SP.Medium	no	no	no	IMP.FH.Medium
SHPSF function which can communicate SHPSF data	no	IMP.FH.DSN.Low	IMP.FH.CCON = IMP.CONF of communicated data	no	IMP.FH = Maximum (IMP.FH.Low, IMP.CONF of communicated data)
connection function	no	IMP.FH.DSN.Medium	no	no	IMP.FH.Medium
SHPSF function which can modify SHPSF data	no	no	no	IMP.FH.MINT = IMP.INT of modified data	IMP.FH = IMP.INT of modified data

Annex E (normative): Protection measures

E.1 Identifier

The following identifier apply here and in the assignment tables in clause 5:

N/A: not applicable

AUTH.Basic: authentication strength level basic

AUTH.Normal: authentication strength level normal

AUTH.Enhanced: authentication strength level enhanced

AUTH.Strong: authentication strength level strong

CONF.COM.Basic: communication of confidential data protection strength level basic

CONF.COM.Normal: communication of confidential data protection strength level normal

CONF.COM.Enhanced: communication of confidential data protection strength level enhanced

CONF.COM.Strong: communication of confidential data protection strength level strong

INT.COM.Basic: communication of integrity relevant data protection strength level basic

INT.COM.Normal: communication of integrity relevant data protection strength level normal

INT.COM.Enhanced: communication of integrity relevant data protection strength level enhanced

INT.COM.Strong: communication of integrity relevant data protection strength level strong

CONF.SSM.Basic: confidential persistent storage strength level basic

CONF.SSM.Normal: confidential persistent storage strength level normal

CONF.SSM.Enhanced: confidential persistent storage strength level enhanced

CONF.SSM.Strong: confidential persistent storage strength level strong

SAN.Normal: input sanitization of input strength level normal

SAN.Strong: input sanitization of input strength level strong

AUT.VER.Enhanced: authenticity verification strength level enhanced

AUT.VER.Strong: authenticity verification strength level strong

INT.SW.VER.Basic: software package integrity verification strength level basic

INT.SW.VER.Normal: software package integrity verification strength level normal

INT.SW.VER.Enhanced: software package integrity verification strength level enhanced

INT.SW.VER.Strong: software package integrity verification strength level strong

INT.VER.Basic: integrity verification strength level basic

INT.VER.Normal: integrity verification strength level normal

INT.VER.Enhanced: integrity verification strength level enhanced

INT.VER.Strong: integrity verification strength level strong

E.2 access control mechanism's strength

E.3 authentication mechanism strength

E.3.1 AUM-FH Authentication for functions whose use can cause harm

E.3.1.1 General

The present document specifies the strength of authentication mechanisms by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

E.3.1.2 authentication strength level basic

The authentication strength level basic shall protect against the following attack types:

limited presentation attack: Opportunistic presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using authentication factors of another entity

limited brute force attack: Opportunistic guessing attacks on authentication mechanisms based on authentication factors of the type knowledge, by guessing manually without the use of technical aids.

E.3.1.3 authentication strength level normal

The authentication strength level normal shall protect against the following attack types:

automated brute force attack: Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical.

presentation attack: Presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using medium effort methods like e.g. photos, cut out masks, audio replays, video replays, AI generated voices

automated security token spoofing attack: Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors sourced from other uses or self-created, without using any specific knowledge of the targeted authentication mechanisms.

replay attack: An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

person in the middle attack: An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

E.3.1.4 authentication strength level enhanced

The authentication strength level enhanced shall protect against the following attack types:

targeted presentation attack: Presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using enhanced effort methods like e.g. (partial) silicone masks, layered prints

targeted brute force attack: Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information.

targeted security token spoofing attack: Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors sourced from devices of the same type as the SHPSF or self-created, using specific knowledge of the targeted authentication mechanisms and the SHPSF.

replay attack: An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

person in the middle attack: An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

E.3.1.5 authentication strength level strong

The authentication strength level strong shall protect against the following attack types:

elaborate presentation attack: Presentation attacks on authentication mechanisms based on authentication factors of the type inheritance", using high effort methods like e.g. highly realistic silicone or latex masks, limb replicas, trained deepfakes

elaborate brute force attack: Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information, and unrestricted duration.

elaborate security token spoofing attack: Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors created or sourced from devices of the same type as the SHPSF and modified, specifically for the targeted authentication mechanisms.

replay attack: An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

person in the middle attack: An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

E.3.2 Assessment for authentication mechanism strength

E.3.2.1 Assessment criteria regarding the protection against limited presentation attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use authentication factors of the type inheritance against limited presentation attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented.

Assessment activities:

- authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine enrolled biometric template identifier, if present, and authentication factors, not belonging to the person who set up the account, for at least five times or ten minutes at highest archivable query frequency;
- the outcome and used authentication factor of each attempt shall be recorded.

Assignment of verdict:

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- description of the performed test;
- all test records of the performed test.

E.3.2.2 Assessment criteria regarding the protection against targeted presentation attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a enhanced level of protection and use authentication factors of the type inherence against targeted presentation attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- authentication factors shall be fabricated using common materials and tools as well as readily available source materials. The fabrication process shall not be longer than *one workday* per authentication factor.

Assessment activities:

- authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least five times with slightly different parameters each;
- the outcome and used authentication factor of each attempt shall be recorded.

Assignment of verdict:

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- description of the performed test;
- all test records of the performed test.

E.3.2.3 Assessment criteria regarding the protection against elaborate presentation attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type inherence against elaborate presentation attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;

- 1595 • a genuine enrolled biometric template in the corresponding authentication mechanism with credential for
- 1596 authentication shall be created;
- 1597 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1598 • authentication factors shall be fabricated using specialized materials and tools as well as cumbersome
- 1599 extracted source materials. The duration of the fabrication process per authentication factor is not restricted.

1600 **Assessment activities:**

- 1601 • authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine
- 1602 enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least
- 1603 five times with slightly different parameters each;
- 1604 • the outcome and used authentication factor of each attempt shall be recorded.

1605 **Assignment of verdict:**

1606 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1607 The verdict FAIL shall be assigned otherwise.

1608 **Supporting Evidence:**

- 1609 • description of the performed test;
- 1610 • all test records of the performed test.

1611 **E.3.2.4 Assessment criteria regarding the protection against limited brute**

1612 **force attacks**

1613 **Assessment objective:**

1614 The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use

1615 authentication factors of the type knowledge against limited brute force attacks.

1616 **Assessment preparation:**

- 1617 • the SHPSF shall be set up in default configuration;
- 1618 • at least one interface, where the authentication mechanism is reachable shall be documented.

1619 The security insurance time (T_{SI}) for this assessment is 10 minutes (600 s)

1620 **Assessment activities:**

1621 The minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be determined; e.g.

1622 $C_{PW,min} = (10)^6$ for a 6-digit PIN or $C_{PW,min} = \frac{9!}{(9-5)!}$ for a pattern of 5 nonrecurring nodes in a field of 9 notes.

1623 The maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $f_{LA,max} = \frac{5}{5*3s+3600s}$ for 3 seconds

1624 per login attempt + a one-hour waiting period after 5 failed login attempts.

1625 The probability of guessing a completely random password of the minimal recommended complexity (p_{GRP}) shall be

1626 calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- 1627 • the methods and outcome of each step shall be recorded.

1628 **Assignment of verdict:**

1629 The verdict PASS shall be assigned if the calculated probability p_{GRP} is less than 10^{-2} .

1630 The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- the authentication mechanism and the interface via which it was accessed;
- all test records of the performed test.

E.3.2.5 Assessment criteria regarding the protection against targeted brute force attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented.

The security insurance time (T_{SI}) for this assessment one month ($2,6 * 10^6 s$)

Assessment activities:

The minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be determined; e.g., $C_{PW,min} = (26 * 2 + 10)^8$ for minimum 8 characters of upper-case or lower-case letters or numbers.

The maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $f_{LA,max} = (0,1s)^{-1}$ for 10 login attempt per second

The probability of guessing a completely random password of the minimal recommended complexity (p_{GRP}) shall be calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- the methods and outcome of each step shall be recorded

Assignment of verdict:

The verdict PASS shall be assigned if the calculated probability p_{GRP} is less than 10^{-6} .

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- the authentication mechanism and the interface via which it was accessed,
- all test records of the performed test

E.3.2.6 Assessment criteria regarding the protection against automated brute force attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented.

The security insurance time (T_{SI}) for this assessment is one day (86 400 s)

1666 **Assessment activities:**

1667 The minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be determined; e.g.
 1668 $C_{PW,min} = (26 * 2 + 10)^8$ for minimum 8 characters of upper-case case or lower-case letters or numbers.

1669 The maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $f_{LA,max} = \frac{5}{5*3s+3600s}$ for 3 seconds
 1670 per login attempt + a one-hour waiting period after 5 failed login attempts.

1671 The probability of guessing a completely random password of the minimal recommended complexity (p_{GRP}) shall be
 1672 calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- 1673 • the methods and outcome of each step shall be recorded

1674 **Assignment of verdict:**

1675 The verdict PASS shall be assigned if the calculated probability p_{GRP} is less than 10^{-6} .

1676 The verdict FAIL shall be assigned otherwise.

1677 **Supporting Evidence:**

- 1678 • the authentication mechanism and the interface via which it was accessed;
- 1679 • all test records of the performed test.

1680 E.3.2.7 Assessment criteria regarding the protection against presentation 1681 attacks

1682 **Assessment objective:**

1683 The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and
 1684 use authentication factors of the type inherence against presentation attacks.

1685 **Assessment preparation:**

- 1686 • the SHPSF shall be set up in default configuration;
- 1687 • a genuine enrolled biometric template in the corresponding authentication mechanism with credential for
 1688 authentication shall be created;
- 1689 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1690 • authentication factors shall be fabricated using readily available materials and tools as well as readily available
 1691 source materials. The fabrication process shall not be longer than *twenty* minutes per authentication factor.

1692 NOTE: Readily available source materials are e.g. fingerprints on everyday items or publicly available photos.
 1693 Readily available materials and tools are of adhesive tape, printer paper, common printers.

1694 **Assessment activities:**

- 1695 • authentication at the created account shall be attempted using the correct account name, if present, and at least
 1696 two fabricated authentication factors tried at least five times with slightly different parameters each;
- 1697 • the outcome and used fabricated authentication factor of each attempt shall be recorded.

1698 **Assignment of verdict:**

1699 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1700 The verdict FAIL shall be assigned otherwise.

1701 **Supporting Evidence:**

- 1702 • description of the performed test;

- all test records of the performed test.

E.3.2.8 Assessment criteria regarding the protection against elaborate brute force attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented.

The security insurance time (T_{SI}) for this assessment is five years ($1,6 * 10^8 s$)

Assessment activities:

The minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be determined; e.g. $(26 * 2 + 10)^8$ for minimum 8 characters of upper-case case or lower-case letters or numbers.

The maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $(0,1s)^{-1}$ for 10 login attempt per second.

The probability of guessing a completely random password of the minimal recommended complexity (p_{GRP}) shall be calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- the methods and outcome of each step shall be recorded

Assignment of verdict:

The verdict PASS shall be assigned if the calculated probability is less than 10^{-6} .

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- the authentication mechanism and the interface via which it was accessed;
- all test records of the performed test.

E.3.2.9 Assessment criteria regarding the protection against automated security token spoofing attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type possession against automated security token spoofing attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- an account in the corresponding authentication mechanism with a security token for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- security tokens, that match specifications of the interfaces, via which the authentication mechanism is reachable, shall be prepared or created without using any specific knowledge of the authentication mechanism.

1739 **Assessment activities:**

- 1740 • authentication at the created account shall be attempted using the correct account name, if present, and the
1741 prepared or created security tokens;
- 1742 • the outcome and used authentication factor of each attempt shall be recorded.

1743 **Assignment of verdict:**

1744 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used
1745 authentication factor exactly matches the configured one.

1746 The verdict FAIL shall be assigned otherwise.

1747 **Supporting Evidence:**

- 1748 • description of the performed test;
- 1749 • all test records of the performed test.

1750 **E.3.2.10 Assessment criteria regarding the protection against targeted**
1751 **security token spoofing attacks**

1752 **Assessment objective:**

1753 The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and
1754 use authentication factors of the type possession against targeted security token spoofing attacks.

1755 **Assessment preparation:**

- 1756 • the SHPSF shall be set up in default configuration;
- 1757 • an account in the corresponding authentication mechanism with a security token for authentication shall be
1758 created;
- 1759 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1760 • security tokens, shall be prepared or created, which match the specifications of the authentication mechanism.

1761 **Assessment activities:**

- 1762 • authentication at the created account shall be attempted using the correct account name, if present, and the
1763 prepared or created security tokens;
- 1764 • the outcome and used authentication factor of each attempt shall be recorded.

1765 **Assignment of verdict:**

1766 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used
1767 authentication factor exactly matches the configured one.

1768 The verdict FAIL shall be assigned otherwise.

1769 **Supporting Evidence:**

- 1770 • description of the performed test;
- 1771 • all test records of the performed test.

E.3.2.11 Assessment criteria regarding the protection against elaborate security token spoofing attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type possession against elaborate security token spoofing attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- an account in the corresponding authentication mechanism with a security token for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- security tokens, shall be prepared or created, which match the specifications of the authentication mechanism and use information extracted from the original security token.

Assessment activities:

- authentication at the created account shall be attempted using the correct account name, if present, and the prepared or created security tokens;
- the outcome and used authentication factor of each attempt shall be recorded.

Assignment of verdict:

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used authentication factor exactly matches the configured one.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- description of the performed test;
- all test records of the performed test.

E.3.2.12 Assessment criteria regarding the protection against replay attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that use authentication factors of the type knowledge or possession (e.g. a session token) against replay attacks.

Assessment preparation:

- the SHPSF shall be set up in default configuration;
- the authentication mechanism shall be active;
- a communication partner with active authentication mechanisms shall be set up for the SHPSF;
- a capture and replay tool between SHPSF and its communication partner shall be set up;
- at least one interface, where the authentication mechanism is reachable shall be documented.

Assessment activities:

- Initiate a connection between the SHPSF and its communication partner.
- Use a capture tool to record the transmitted message or transaction data.

1808 • Replay (retransmit) the captured message to the product using a suitable tool in place to mimic the original
1809 communication partner.

1810 • Record if the product accepts the retransmitted data.

1811 **Assignment of verdict:**

1812 The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.

1813 The verdict FAIL shall be assigned otherwise.

1814 **Supporting Evidence:**

1815 • description of the performed test;

1816 • all test records of the performed test.

1817 **E.3.2.13 Assessment criteria regarding the protection against PitM attacks**

1818 **Assessment objective:**

1819 The assessment covers functional testing of authentication mechanisms that use authentication factors of the type
1820 knowledge or possession (e.g. a session token) against PitM attacks.

1821 **Assessment preparation:**

1822 • the SHPSF shall be set up in default configuration;

1823 • the authentication mechanism shall be active;

1824 • a communication partner with active authentication mechanisms shall be set up for the SHPSF;

1825 • a capture and PitM tool between SHPSF and its communication partner shall be set up;

1826 • at least one interface, where the authentication mechanism is reachable shall be documented.

1827 **Assessment activities:**

1828 • Initiate a connection between the SHPSF and its communication partner.

1829 • Attempt to capture data (consumer credentials, tokens, etc.) with the tool in place and actively intercept
1830 communication to impersonate the communication partner during:

1831 - generation and communication of authentication factors for the communication partner (if not
1832 pre-configured); and

1833 - authentication of the communication partner.

1834 • Record if the impersonation as communication partner is successful.

1835 **Assignment of verdict:**

1836 The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.

1837 The verdict FAIL shall be assigned otherwise.

1838 **Supporting Evidence:**

1839 • description of the performed test;

1840 • all test records of the performed test.

E.4 confidentiality protection strength

E.4.1 CONF-SSM Confidentiality protecting persistent storage for confidential data

E.4.1.1 General

The present document specifies confidentiality protecting secure storage mechanisms' strength, by certain security properties. Those properties are constructed such that mechanisms of higher strength have the properties of lower strength mechanisms.

E.4.1.2 confidential persistent storage strength level basic

Mechanisms for the confidential persistent storage strength level basic shall encrypt such that decryption is only possible for the SHPSF.

E.4.1.3 confidential persistent storage strength level normal

Mechanisms for the confidential persistent storage strength level normal shall encrypt such that decryption is:

- only possible for the SHPSF; and
- only performed after a successful authentication.

E.4.1.4 confidential persistent storage strength level enhanced

Mechanisms for the confidential persistent storage strength level enhanced shall encrypt supported by hardware, such that:

- decryption is only possible for the SHPSF after a successful authentication; and
- the extraction of the encryption key is prevented by hardware.

E.4.1.5 confidential persistent storage strength level strong

Mechanisms for the confidential persistent storage strength level strong shall prevent the extraction of data by hardware.

E.5 confidentiality protection strength

E.5.1 CONF-COM Communication of confidential data

E.5.1.1 General

The present document specifies the strength of mechanisms to protect the confidentiality of communicated confidential data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

E.5.1.2 communication of confidential data protection strength level basic

The communication of confidential data protection strength level basic shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the SHPSF and another entity or another part of the SHPSF.

E.5.1.3 communication of confidential data protection strength level normal

The communication of confidential data protection strength level normal shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the SHPSF and another entity or another part of the SHPSF.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the SHPSF.

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol.

E.5.1.4 communication of confidential data protection strength level enhanced

The communication of confidential data protection strength level enhanced shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the SHPSF and another entity or another part of the SHPSF.

person in the middle attack: An attacker secretly alters the communication between the SHPSF and another entity or another part of the SHPSF to gain a trusted relationship with the involved communication partners without their knowledge.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the SHPSF.

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol.

E.5.1.5 communication of confidential data protection strength level strong

The communication of confidential data protection strength level strong shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the SHPSF and another entity or another part of the SHPSF.

person in the middle attack: An attacker secretly alters the communication between the SHPSF and another entity or another part of the SHPSF to gain a trusted relationship with the involved communication partners without their knowledge.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the SHPSF.

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol.

E.6 integrity protection strength

E.6.1 INT-SWPCK Software package verification

E.6.1.1 General

The present document specifies software package verification mechanisms' strength, by certain protection measures. Those measures are constructed such that measures of higher strength typically have less attack vectors than lower strength measures.

E.6.1.2 software package integrity verification strength level basic

Mechanisms for the software package integrity verification strength level basic shall:

- explicitly obtain the confirmation of an authorized entity that the integrity and authenticity of a software package has been verified by the entity, where the software package's source is determined by the entity; or
- explicitly obtain the confirmation of an authorized entity that the authenticity of a software package has been verified by the entity and use a hash or checksum provided by the entity for the software package to verify its integrity, where the software package's source is determined by the entity.

E.6.1.3 software package integrity verification strength level normal

Mechanisms for the software package integrity verification strength level normal shall ensure that a software package has been obtained from a trusted source over a secure communication channel that meets INT.COM.Enhanced.

E.6.1.4 software package integrity verification strength level enhanced

Mechanisms for the software package integrity verification strength level enhanced shall verify the authenticity and integrity of a software package using cryptographic digital signature verification.

E.6.2 INT-COM Communication of integrity relevant data

E.6.2.1 General

The present document specifies the strength of mechanisms to protect the integrity of communicated integrity relevant data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

E.6.2.2 communication of integrity relevant data protection strength level basic

The communication of integrity relevant data protection strength level basic shall protect against the following attack types:

accidental bit flip: Accidental change of data by natural causes.

E.6.2.3 communication of integrity relevant data protection strength level normal

The communication of integrity relevant data protection strength level normal shall protect against the following attack types:

replay attack: An attacker intercepts valid transmissions and then retransmits those captured messages to the same interface to deceive it into performing unauthorized actions.

accidental bit flip: Accidental change of data by natural causes.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the SHPSF.

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol.

E.6.2.4 communication of integrity relevant data protection strength level enhanced

The communication of integrity relevant data protection strength level enhanced shall protect against the following attack types:

replay attack: An attacker intercepts valid transmissions and then retransmits those captured messages to the same interface to deceive it into performing unauthorized actions.

person in the middle attack: An attacker secretly alters the communication between the SHPSF and another entity or another part of the SHPSF to gain a trusted relationship with the involved communication partners without their knowledge.

accidental bit flip: Accidental change of data by natural causes.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the SHPSF.

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol.

E.6.2.5 communication of integrity relevant data protection strength level strong

The communication of integrity relevant data protection strength level strong shall protect against the following attack types:

replay attack: An attacker intercepts valid transmissions and then retransmits those captured messages to the same interface to deceive it into performing unauthorized actions.

person in the middle attack: An attacker secretly alters the communication between the SHPSF and another entity or another part of the SHPSF to gain a trusted relationship with the involved communication partners without their knowledge.

accidental bit flip: Accidental change of data by natural causes.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the SHPSF.

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol.

Annex F (informative): Relationship between the present document and the covered/not covered cybersecurity risks

Table F.1 shows the threat scenarios considered, the mitigation measures related to them in this document with associated attack surface parameters, and the risk coverage.

Table F.1: Covered threats and remaining risks acceptance

No.	Threat Actor	Threat action	Asset	Threat details		Requirement(s) for mitigation	Relevant attack surface parameter	Risk coverage
[1]	A threat actor	(mis)uses	a function whose use can cause harm	on the SHPSF		Prevention: [ACM-FH] 5.1.3.1 [AUM-FH] 5.1.3.2 [AUTHZ-LP] 5.1.3.3 [AUTHZ-R] 5.1.3.4 [AVAI-TIME-IMP-AMP] 5.1.7.8 [LAS-PHY-INF] 5.1.9.3 [LAS-LOGIC-INF] 5.1.9.4 [LAS-APP] 5.1.9.5 [SDC-AUM-FH] 5.1.2.1 Information: [LOG-LOW] 5.1.10.1 [LOG-MEDIUM] 5.1.10.2 [LOG-HIGH] 5.1.10.3 [LOG-TIME] 5.1.10.4 [LOG-TIME-HIGH] 5.1.10.5 [LOG-STORAGE] 5.1.10.6 [LOG-BACKUP] 5.1.10.7 [USERNOT-NOSECFUC] 5.1.12.1 Restoration: [SDC-FRM] 5.1.2.4	COM, IF and POE	C
[2]		tamper	integrity relevant data	permanently stored on the SHPSF				N
[3]				volatile stored on the SHPSF				N
[4]				communicated from or to the MP or RDPS		Prevention: [INT-COM] 5.1.4.2	COM, IF and POE	C
[5]		discloses	confidential data	on the SHPSF	unnecessarily processed	Prevention: [DMIN-DJST] 5.1.6.1		C
[6]				permanently stored on the SHPSF	during storage	Prevention: [CONF-SSM] 5.1.5.1	POE	C
[7]					after deletion			N
[8]				volatile stored on the SHPSF	during usage			N
[9]					after usage			N
[10]				communicated from or to the MP or RDPS		Prevention: [CONF-COM] 5.1.5.2	COM, IF and POE	C

No.	Threat Actor	Threat action	Asset	Threat details		Requirement(s) for mitigation	Relevant attack surface parameter	Risk coverage
[11]		tamper s	loss sensitive data	permanently stored on the SHPSF	during storage			N
[12]			integrity relevant function	on the SHPSF		Prevention: [INT-SWPCK] 5.1.4.1 [LAS-SBOOT] 5.1.9.6		N
[13]		impact s the availability of	time sensitive function		by interruption caused by a software update installation	Prevention: [AVAI-SUM-SCHEDULE] 5.1.7.10		C
[14]					by interruption of power supply	Information: [AVAI-TIME-OUTA-NOT] 5.1.7.4 [AVAI-TIME-PREV-NOT] 5.1.7.5 Restoration: [AVAI-TIME-RECO-POW] 5.1.7.1		C
[15]					by interruption of network connection	Prevention: [AVAI-TIME-NETW] 5.1.7.2 Information: [AVAI-TIME-OUTA-NOT] 5.1.7.4 [AVAI-TIME-PREV-NOT] 5.1.7.5 Restoration: [AVAI-TIME-RECO-NETW] 5.1.7.3		C
[16]					due to overloading of a resource or connection	Prevention: [AVAI-TIME-NET-PRIO] 5.1.7.6 [AVAI-TIME-RES-PRIO] 5.1.7.7 [AVAI-TIME-DOS-RATE] 5.1.7.9 Information: [AVAI-TIME-OUTA-NOT] 5.1.7.4	IF	C
[17]		exploit s an implementation vulnerability to compromise	a product cybersecurity asset			Prevention: [LAS-INVAL] 5.1.9.1 [LAS-INSAN] 5.1.9.2 [NKEV-MKAV] 5.1.1.1 Information: [NKEV-SUM-NOTIF] 5.1.1.5 [SDC-SUM-NOTIF] 5.1.2.3 Restoration: [NKEV-SUM-SUPPORT] 5.1.1.2 [NKEV-SUM-PROVIDE] 5.1.1.3 [NKEV-SUM-AUTO] 5.1.1.4 [SDC-SUM-AUTO] 5.1.2.2		C

1974

1975
1976

- The columns *Threat Actor*, *Threat Action*, *Asset*, and *Threat Details* describe the threat scenario under consideration.

1977
1978

- The column *Requirement(s) for mitigation* refers to the mitigations of the risks that arise from the threat scenario.

1979
1980

- The *Relevant attack surface parameter* column describes which of the attack surface parameters make a difference in mitigation.

- 1981
- 1982
- 1983
- The *Risk coverage* column describes whether the risk associated with the threat scenario has been reduced to an acceptable residual risk (C) or not (N).

1984

Annex G (informative):

1985

Relationship between the present document and ETSI EN

1986

303 645/ ETSI TS 103 701

1987

This informative annex is intended to provide a mapping between the present document and the content of ETSI

1988

TC CYBER's existing work on CIoT devices (ETSI EN 303 645/ ETSI TS 103 701).

1989

1990

History

Version	Date	Status
V0.2.0	February 2026	Clean-up done by <i>editHelp!</i> E-mail: mailto:edithelp@etsi.org

1991